

Lab 2: Web Application Security Testing

Student Name: Maryjudith Chidinma Ogunaka

Registration Number: C11/26/FCDF/17151

Programme: ICDFA Trainee | Cohort 11

Lab Title: Lab 2: Web Application Security Testing

Date: 06 September 2026

Authorised Target: DVWA and OWASP Mutillidae Training Applications

DVWA Target IP Address: 10.15.203.233

Mutillidae Target IP Address: 10.234.230.91

Executive Summary

This lab focused on the assessment of web application security using the intentionally vulnerable applications DVWA (Damn Vulnerable Web Application) and Mutillidae within an authorized training environment. The objective of the exercise was to gain practical experience with common web security assessment techniques while understanding how vulnerabilities can affect the confidentiality, integrity, and availability of information systems.

The assessment began with the examination of web application functionality using browser developer tools and Burp Suite. HTTP requests, responses, cookies, and application parameters were inspected to understand how information is exchanged between users and web applications. File upload security controls were also evaluated by performing normal file uploads and extension-handling tests within DVWA.

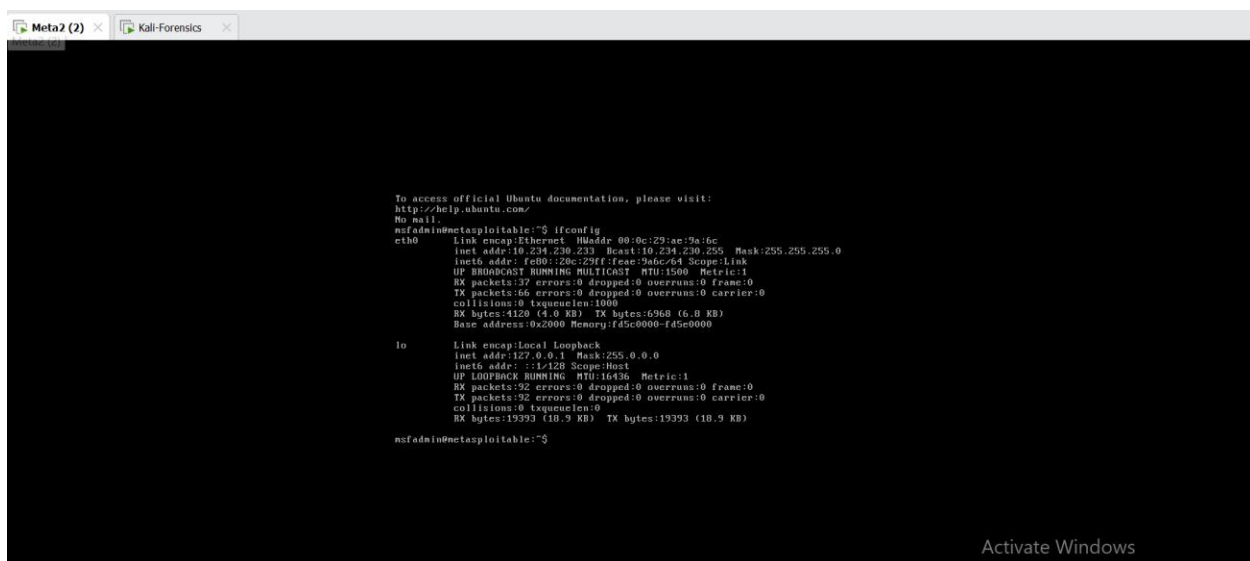
Web server assessment activities were conducted using Nikto and DIRB. Nikto was used to identify server configuration observations and potential security weaknesses, while DIRB was used to discover web-accessible directories and resources. These activities provided insight into the structure of the target web applications and highlighted the importance of secure server configuration and content management.

The second phase of the exercise focused on SQL injection concepts using the Mutillidae application. User-controlled inputs were identified, baseline behavior was established, and special SQL characters and logical conditions were tested to observe application responses. The exercise demonstrated how improper handling of user input can expose applications to security risks and information disclosure.

SQLMap was subsequently used to automate SQL injection assessment activities. The tool successfully analyzed target parameters and attempted database enumeration and table enumeration. Although no confirmed injectable parameter was identified during the automated assessment, the exercise demonstrated how automated security testing tools can complement manual testing techniques.

During the exercise, the target virtual machine received different IP addresses due to dynamic network assignment within the virtual environment. Testing initially used IP address **10.15.203.233** and later continued using **10.234.230.91** after connectivity was re-established. This change did not affect the assessment because testing continued against the same authorized target system.

Overall, the lab provided practical experience in web application assessment, file upload security, server enumeration, directory discovery, SQL injection concepts, and automated vulnerability testing. The exercise reinforced the importance of secure coding practices, server-side validation, prepared statements, proper error handling, secure file storage, and authorized security testing procedures.



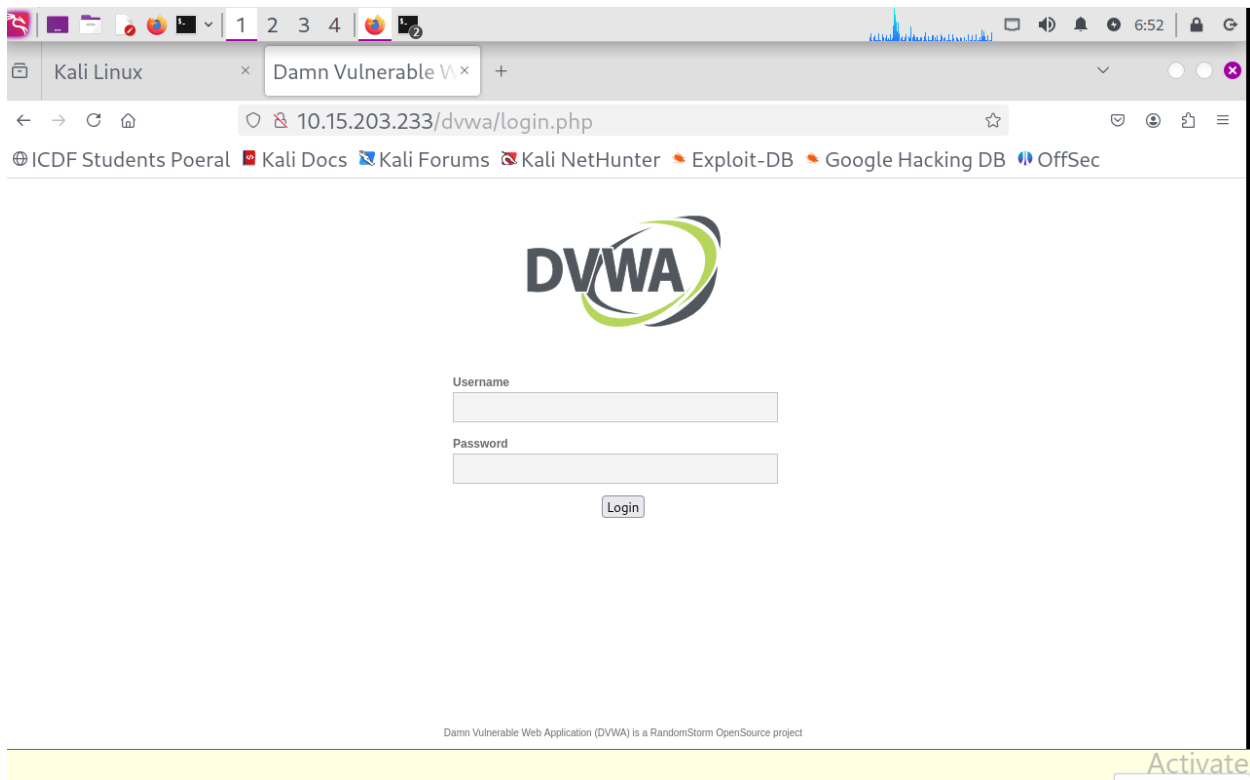
```
Meta2 (2) x Kali-Forensics x
nsfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:ae:9a:6c
          inet addr:10.234.230.233  Bcast:10.234.230.255  Mask:255.255.255.0
          inet6 addr: fe80::28c:23ff:fee:9a6c/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:37 errors:0 dropped:0 overruns:0 frame:0
          TX packets:46 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:4120 (4.0 KB)  TX bytes:6968 (6.8 KB)
          Base address:0x2000 Memory:fd5c0000-fd5e0000

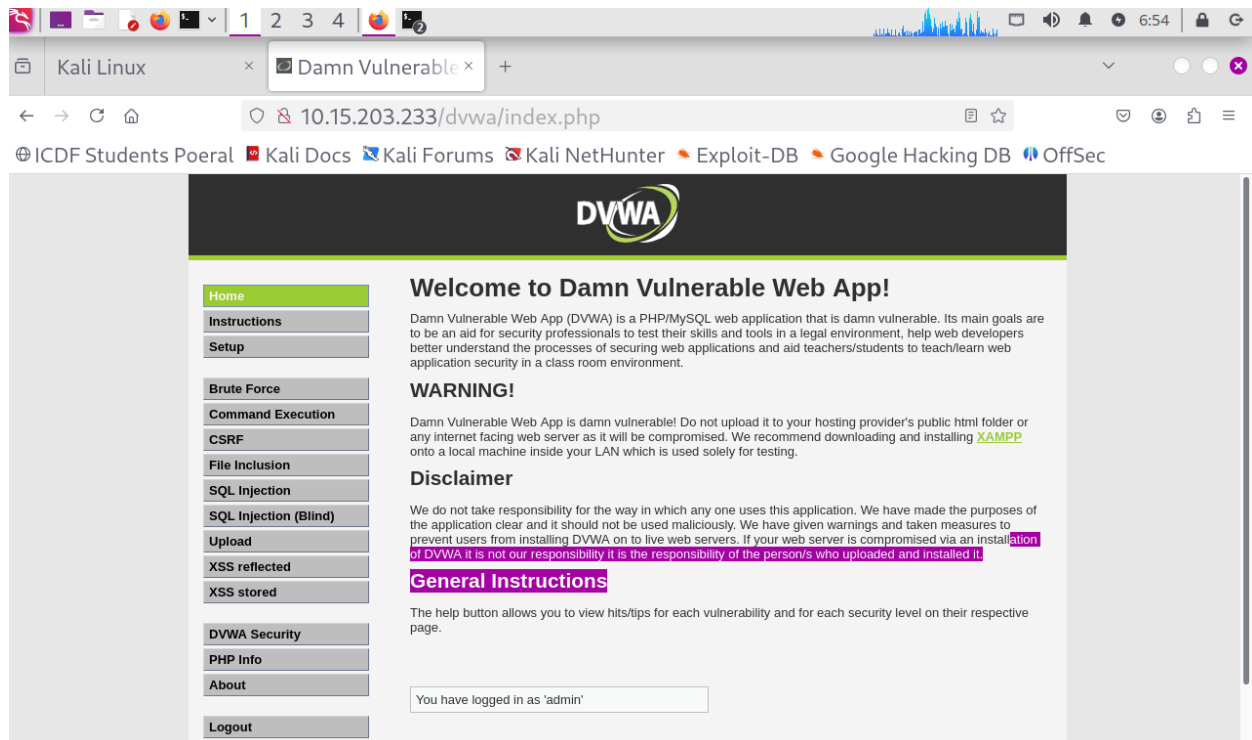
lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1:128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:32 errors:0 dropped:0 overruns:0 frame:0
          TX packets:32 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:19393 (18.9 KB)  TX bytes:19393 (18.9 KB)

nsfadmin@metasploitable:~$
```

Activate Windows
Go to Settings to activate Windows.

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
(icdfa@maryjudith)-[~]  
$ ping 10.15.203.233 -c 4  
PING 10.15.203.233 (10.15.203.233) 56(84) bytes of data.  
64 bytes from 10.15.203.233: icmp_seq=1 ttl=64 time=1.41 ms  
64 bytes from 10.15.203.233: icmp_seq=2 ttl=64 time=1.79 ms  
64 bytes from 10.15.203.233: icmp_seq=3 ttl=64 time=1.72 ms  
64 bytes from 10.15.203.233: icmp_seq=4 ttl=64 time=0.508 ms  
  
— 10.15.203.233 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3007ms  
rtt min/avg/max/mdev = 0.508/1.358/1.790/0.511 ms  
  
(icdfa@maryjudith)-[~]  
$
```

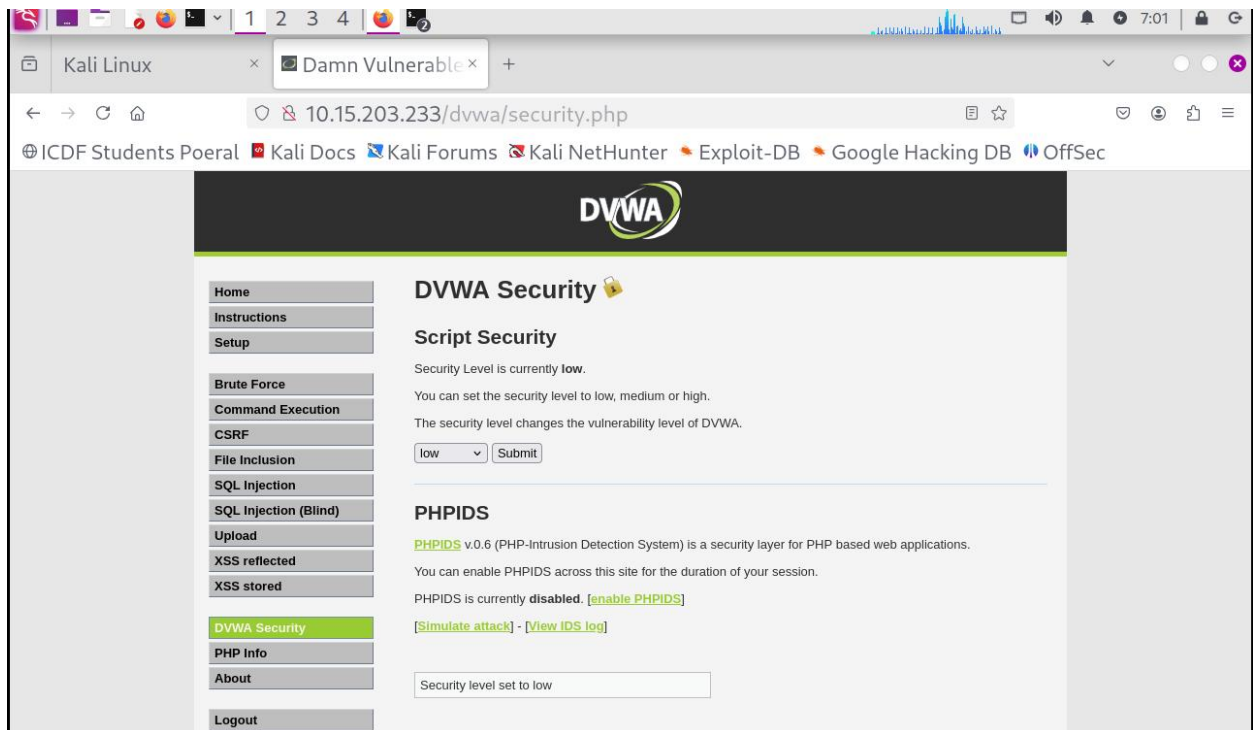
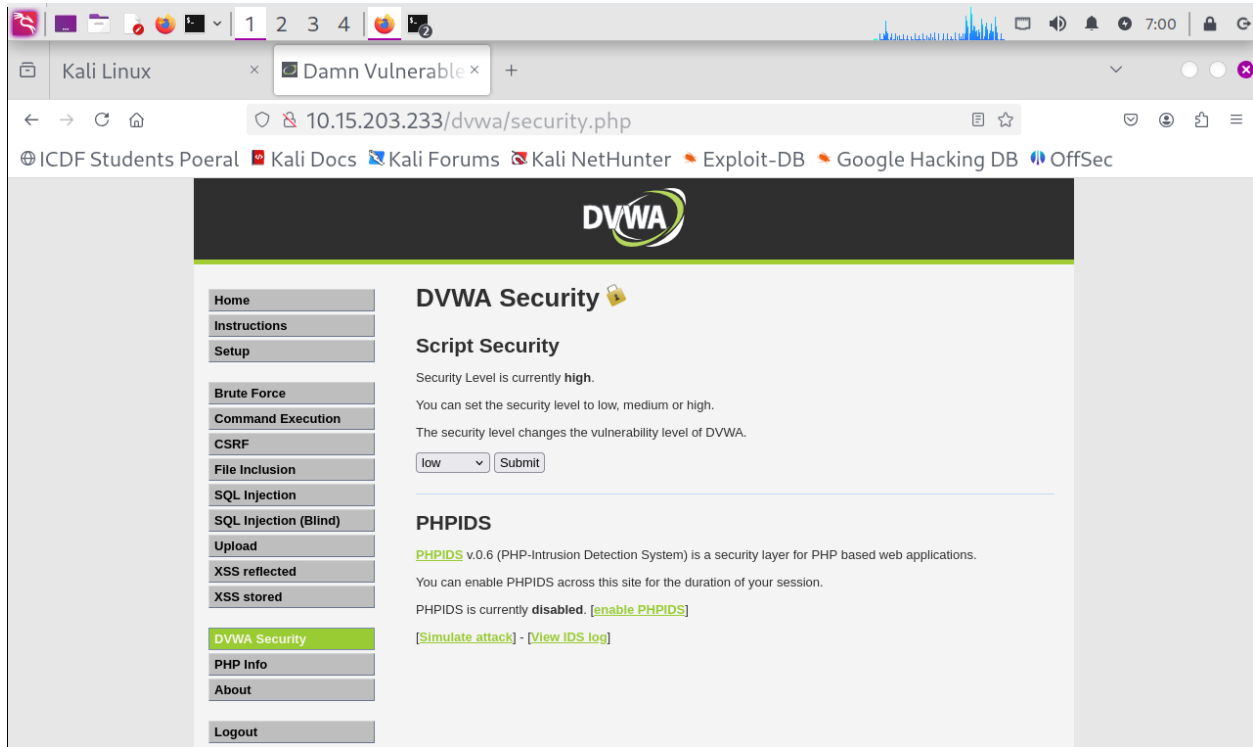




Report

The DVWA web application was accessed successfully through the Firefox browser using the assigned target IP address. The URL directed the browser to the Damn Vulnerable Web Application (DVWA) login page hosted on the authorized lab machine. The page loaded correctly without any connectivity or server-related errors, confirming that the web service was active and reachable. This step established the target application that would be used throughout the web application security testing exercise. Verifying the correct URL before testing helped ensure that all subsequent activities were conducted within the approved laboratory environment.

Step 2: Set DVWA Security Level to Low



REPORT

After logging into DVWA, the DVWA Security section was opened from the navigation menu. The security level was changed to Low and the configuration was submitted successfully. The page refreshed and displayed Low as the active security setting, confirming that the change had been applied. Setting the security level to Low created a predictable training environment where intentionally vulnerable features could be examined more easily. This configuration was necessary to ensure that the file upload and SQL injection exercises behaved as expected during the lab.

Step 3: Open Network tools

The screenshot shows a web browser window with the URL `10.15.203.233/dvwa/security.php`. The page title is "DVWA Security". On the left, there is a navigation menu with options: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, and DVWA Security (which is highlighted). The main content area is titled "Script Security" and shows "Security Level is currently low." with a dropdown menu set to "low" and a "Submit" button. Below this, the "PHPIDS" section is visible, stating "PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications." and "PHPIDS is currently disabled." with a link to "[enable PHPIDS]".

The Chrome DevTools Inspector is open at the bottom, showing the HTML structure of the page. The selected element is `<body class="home">`. The CSS styles for `body` are displayed on the right, including `background-color: #e7e7e7;`, `margin: 0;`, `color: #2f2f2f;`, `font: 12px/15px Arial, Helvetica, sans-serif;`, `min-width: 981px;`, `height: 100%;`, and `position: relative;`.

Kali Linux x Damn Vulnerable x Settings x +

10.15.203.233/dvwa/security.php

ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low Submit

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Filter URLs

Perform a request or Reload the page to see detailed information about network activity.

Click on the button to start performance analysis.

No requests

Kali Linux x Damn Vulnerable x Settings x +

10.15.203.233/dvwa/security.php

ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low Submit

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

10.15.203.233/dvwa/security.php?phpids=on

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility Application

Filter URLs

Status	Method	Domain	File	Initiator	Type	Transferred	Size	0 ms	16 ms	0 ms	320 ms
200	GET	10.15.203.233	security.php	document	html	4.45 kB	4.10 kB				
200	GET	10.15.203.233	dvwaPage.js	script	js	cached	775 B			0 ms	
200	GET	10.15.203.233	logo.png	img	png	cached	8.30 kB			0 ms	
200	GET	10.15.203.233	lock.png	img	png	cached	1.39 kB			0 ms	
200	GET	10.15.203.233	favicon.ico	FaviconLoader.sys.mis1...	x-icon	cached	1.41 kB				0 ms

5 requests 15.98 kB / 4.45 kB transferred Finish: 400 ms DOMContentLoaded: 134 ms load: 148 ms

REPORT

The Firefox Developer Tools Network tab was opened to observe the communication between the browser and the DVWA web application. After reloading the page, multiple HTTP requests and responses became visible within the Network panel. A request to the DVWA Security page was identified and examined to understand how the browser interacts with the web server. The request details included the HTTP method, requested URL, response status code, and associated headers. Observing normal network traffic before using Burp Suite provided a baseline understanding of the application's standard behavior.

Step 4: Identify cookies

The screenshot shows a web browser window with the address bar displaying `10.15.203.233/dvwa/security.php`. The page content includes a sidebar with navigation links (Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, DVWA Security) and a main content area titled "DVWA Security" with sections for "Script Security" and "PHPIDS".

The Firefox Developer Tools Network tab is open, showing a list of requests. The first request is highlighted:

Status	Method	Domain	File	Initiator	Type	Transferred	Size
200	GET	10.15.203.233	security.php	document	html	4.45 kB	4.10 kB
200	GET	10.15.203.233	dvwaPage.js	script	js	cached	775 B
200	GET	10.15.203.233	logo.png	img	png	cached	8.30 kB
200	GET	10.15.203.233	lock.png	img	png	cached	1.39 kB
200	GET	10.15.203.233	favicon.ico	FaviconLoader...	x-icon	cached	1.41 kB

The "Headers" tab is selected for the first request, showing the following details:

Header	Value
Status	200 OK
Version	HTTP/1.1
Transferred	4.45 kB (4.10 kB size)
Referrer Policy	strict-origin-when-cross-origin
Request Priority	Highest

The screenshot shows a web browser window with the address bar at `10.15.203.233/dvwa/security.php`. The page title is "DVWA Security". The left sidebar contains a list of links: Home, Instructions, Setup, Brute Force, Command Execution, CSRF, File Inclusion, SQL Injection, SQL Injection (Blind), Upload, XSS reflected, XSS stored, and DVWA Security (highlighted). The main content area is titled "Script Security" and shows the security level is currently low. Below this, there is a section for PHPIDS, which is currently disabled. The network inspector at the bottom shows a list of requests, with the first request (GET /security.php) selected. The "Cookies" tab is active, showing the following cookies:

Name	Value
PHPSESSID	"c9781e530f911487732c97097dfb9047"
security	"low"

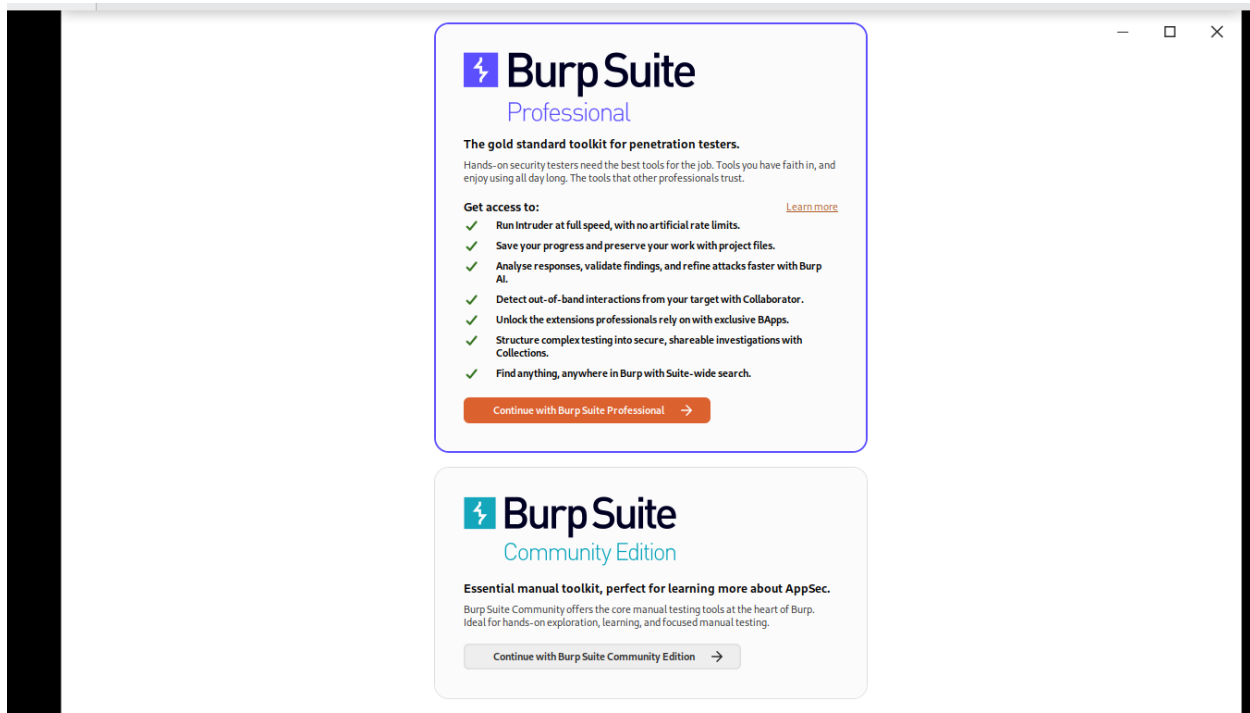
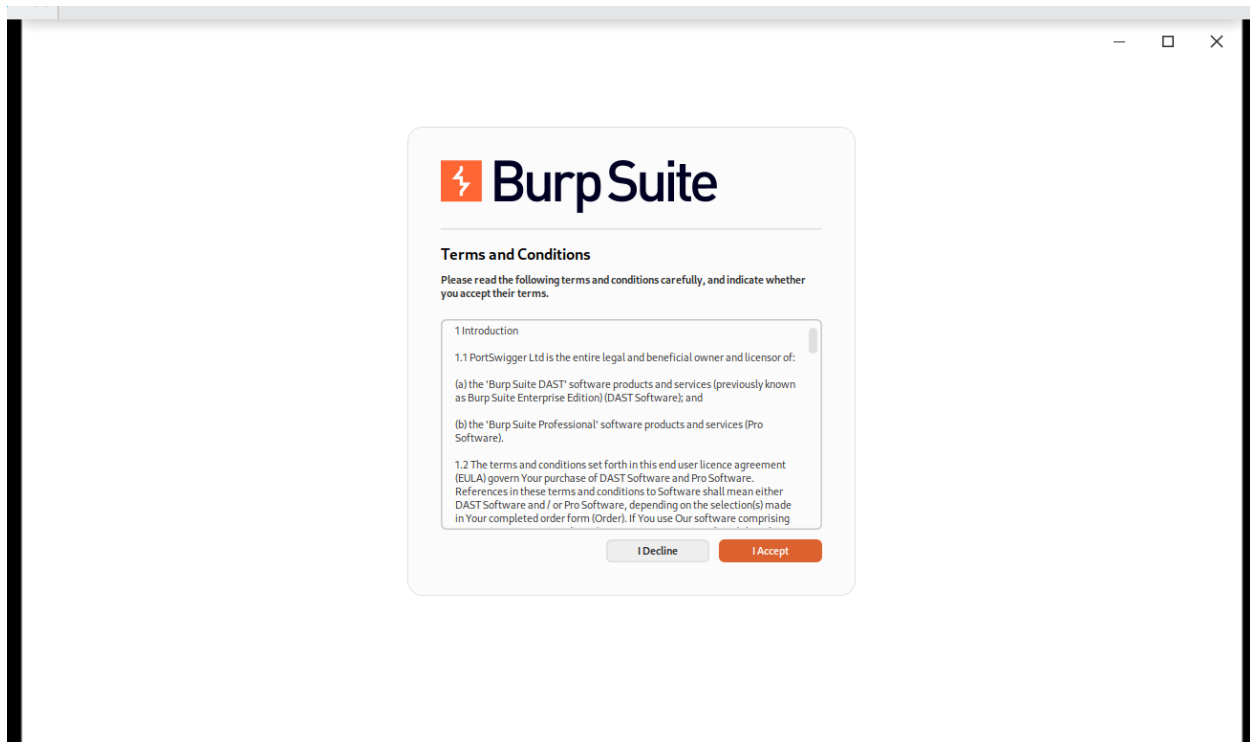
REPORT

The cookie information associated with the DVWA application was identified through the browser developer tools. Cookies were present within the request data and were used by the application to maintain session information and store security-level settings. Two cookie names were observed during the inspection, namely **PHPSESSID** and **security**. These cookies help the server recognize authenticated users and preserve application state across multiple requests. To maintain security and prevent session disclosure, only the cookie names were recorded while the actual cookie values were deliberately excluded from the report.

Step 5: Start Burp Suite

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
$ burpsuite  
Command 'burpsuite' not found, but can be installed with:  
sudo apt install burpsuite  
Do you want to install it? (N/y)y  
sudo apt install burpsuite  
sudo: unable to resolve host maryjudith: Name or service not known  
[sudo] password for icdfa:  
The following packages were automatically installed and are no longer required:  
libcaes1 libscca1t64 python3-libfswi  
libcreg1t64 libxnnpack0 python3-liblnk  
libdnnl3 python3-acstore python3-libmsiecf  
libevt1t64 python3-cffi python3-libolecf  
libevtx1t64 python3-elasticsearch python3-libscca  
libfswi1t64 python3-flor python3-pefile  
libglapi-mesa python3-libcreg python3-pycaes  
libmsiecf1t64 python3-libesedb python3-pycparser  
libolecf1 python3-libevt python3-zstd  
libopenh264-7 python3-libevtx  
Use 'sudo apt autoremove' to remove them.
```

```
Use 'sudo apt autoremove' to remove them.  
Installing:  
burpsuite  
Summary:  
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2635  
Download size: 344 MB  
Space needed: 361 MB / 4,556 MB available  
Get:1 http://kali.download/kali kali-rolling/main amd64 burpsuite amd64 2026.8-0kali1 [344 MB]  
Fetched 344 MB in 1min 7s (5,150 kB/s)  
Selecting previously unselected package burpsuite.  
(Reading database ... 419533 files and directories currently installed.)  
Preparing to unpack .../burpsuite_2026.8-0kali1_amd64.deb ...  
Unpacking burpsuite (2026.8-0kali1) ...  
Setting up burpsuite (2026.8-0kali1) ...  
Processing triggers for kali-menu (2025.1.1) ...  
(icdfa@maryjudith)-[~]
```



File Actions Edit View Help

burpsuite

Summary:
Upgrading: 0,
Download size:
Space needed:

set:1 http://kal
8-0kali1 [344 M
etched 344 MB i
selecting previo
Reading databas
Preparing to unp
Unpacking burpsu
Setting up burps
Processing trigg

—(icdfa@maryj
\$ burpsuite

warning] /usr/bin/burpsuite: No JAVA_CMD set for run_java, falling back to
JAVA_CMD = java

Burp Suite Community Edition v2026.8

Welcome to Burp Suite Community Edition. Use the options below to create or open a project.

☒ Temporary project in memory

Project files are Burp Suite Professional only [Upgrade now](#)

☐ New project on disk

Name:

File: [Choose file...](#)

☐ Open existing project

Name	File	Last Accessed

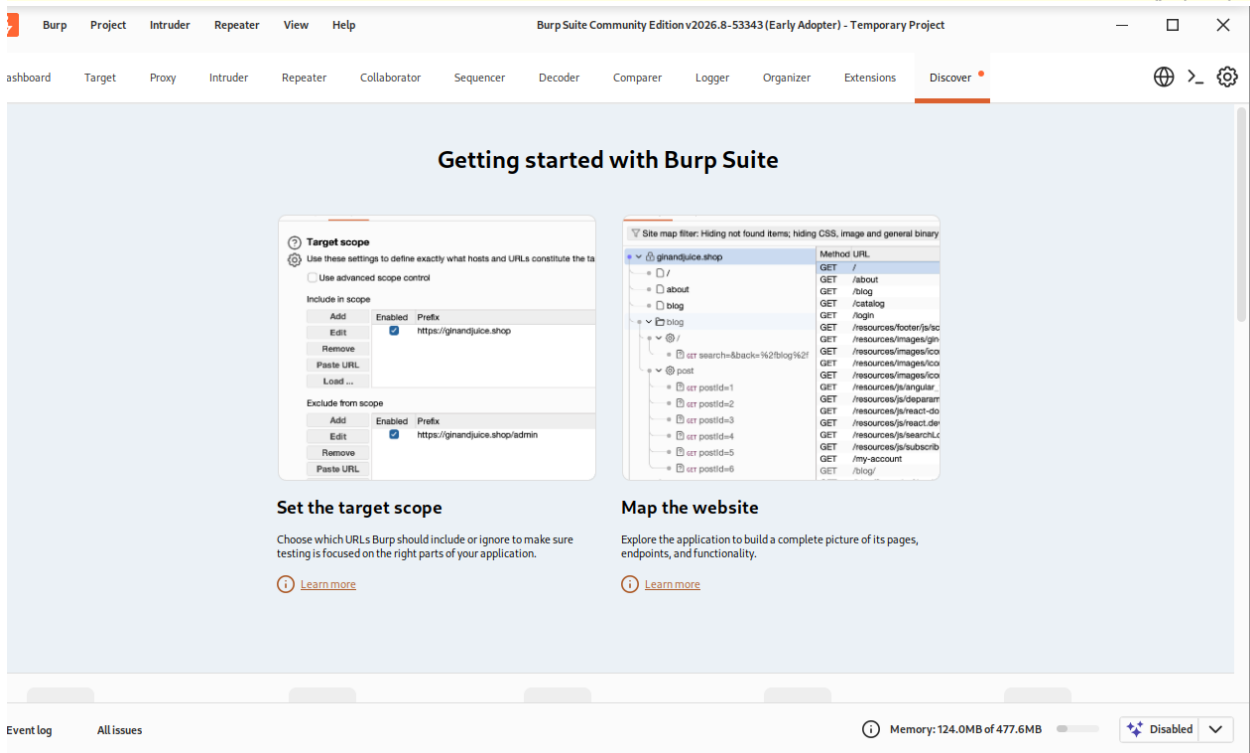
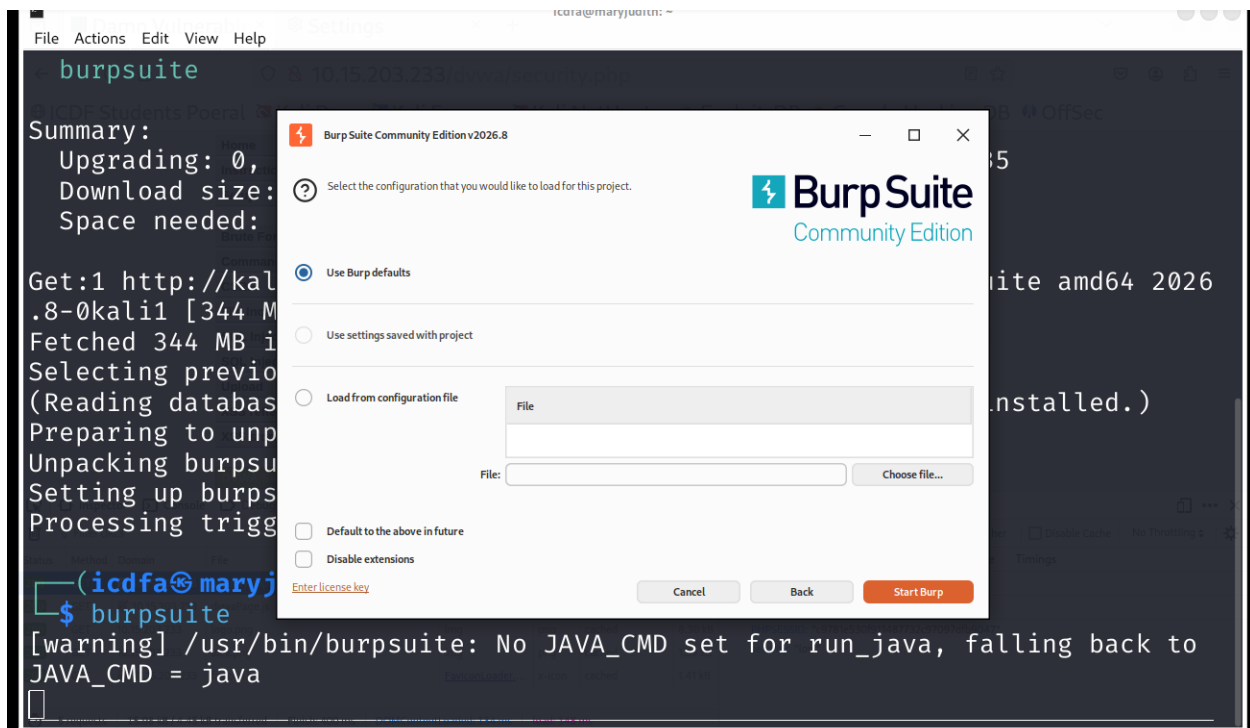
File: [Choose file...](#)

☒ Trust this project file

☐ Pause automated tasks

[Enter license key](#)

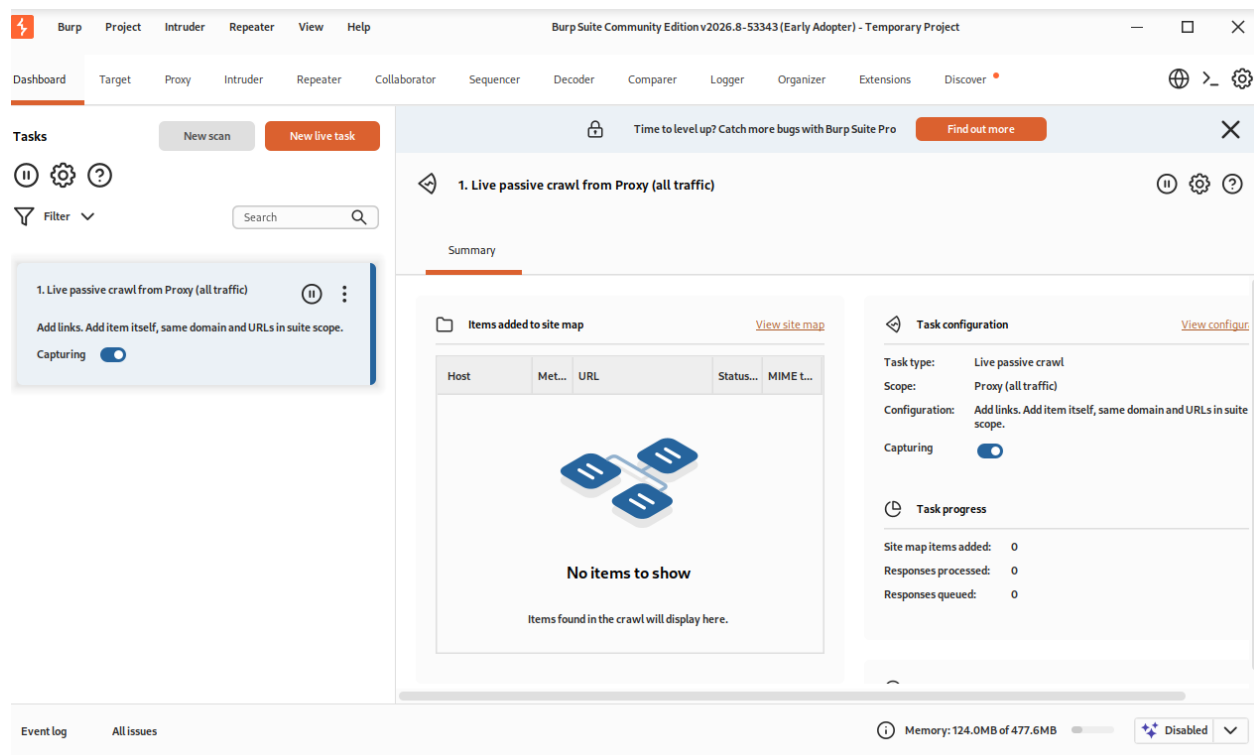
[Cancel](#) [Next](#)

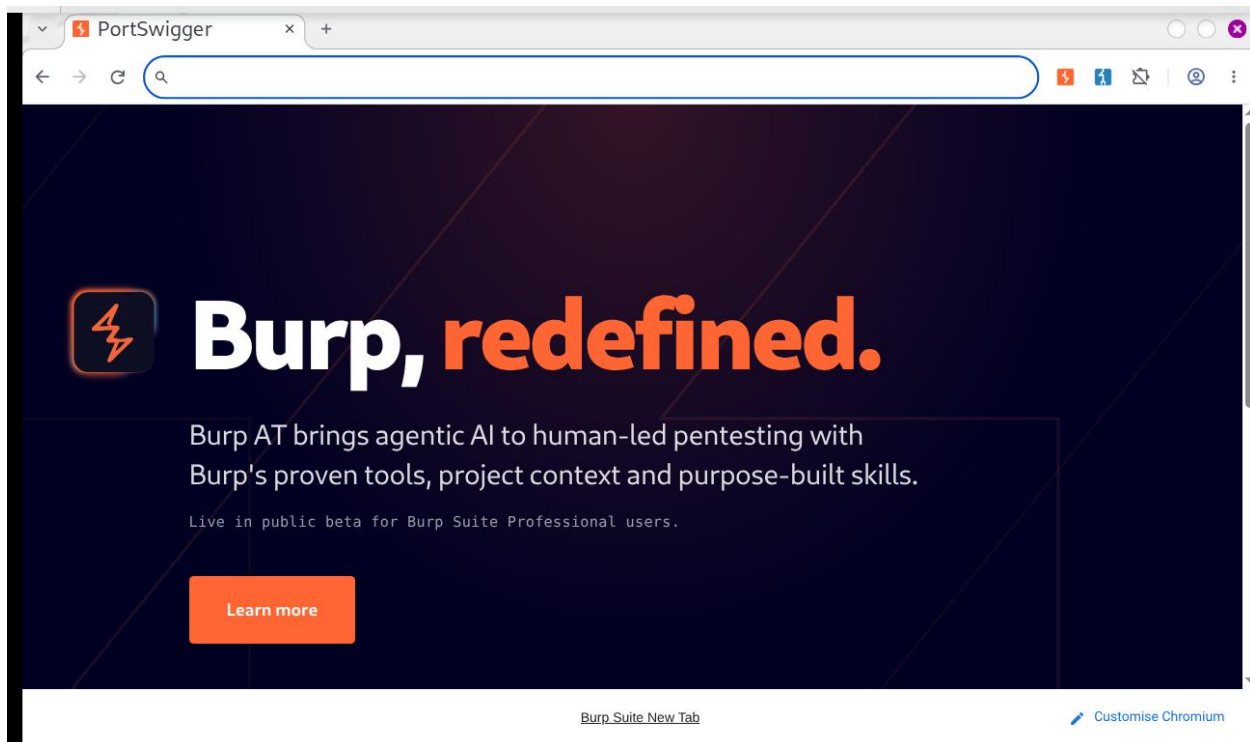
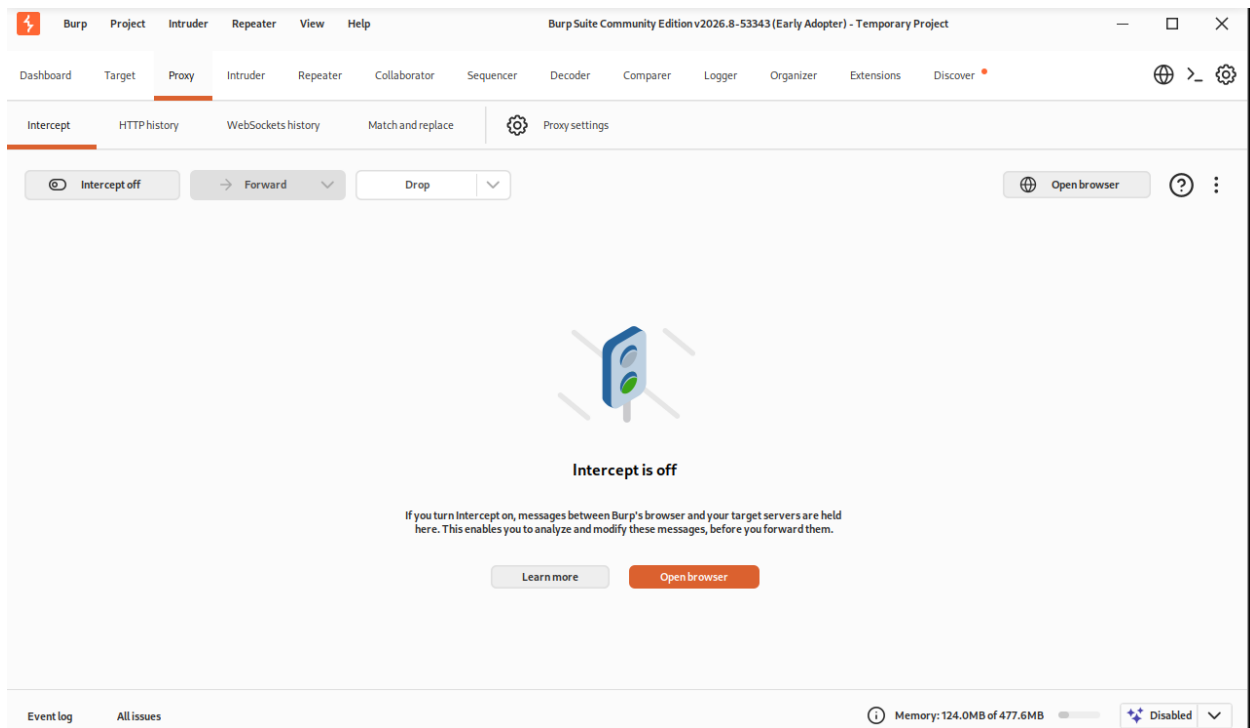


REPORT

Burp Suite was launched successfully on the Kali Linux system and configured using a temporary project for the duration of the exercise. The tool initialized correctly and provided access to its various testing modules, including Proxy, Target, Repeater, and Intruder. Burp Suite functions as an intercepting proxy that allows HTTP requests and responses to be viewed, intercepted, and analyzed before reaching the target web application. This capability helps security testers understand how user input is transmitted and processed by the server. The successful launch of Burp Suite confirmed that the environment was ready for web traffic interception and further application testing.

Step 6: Open Burp Browser.

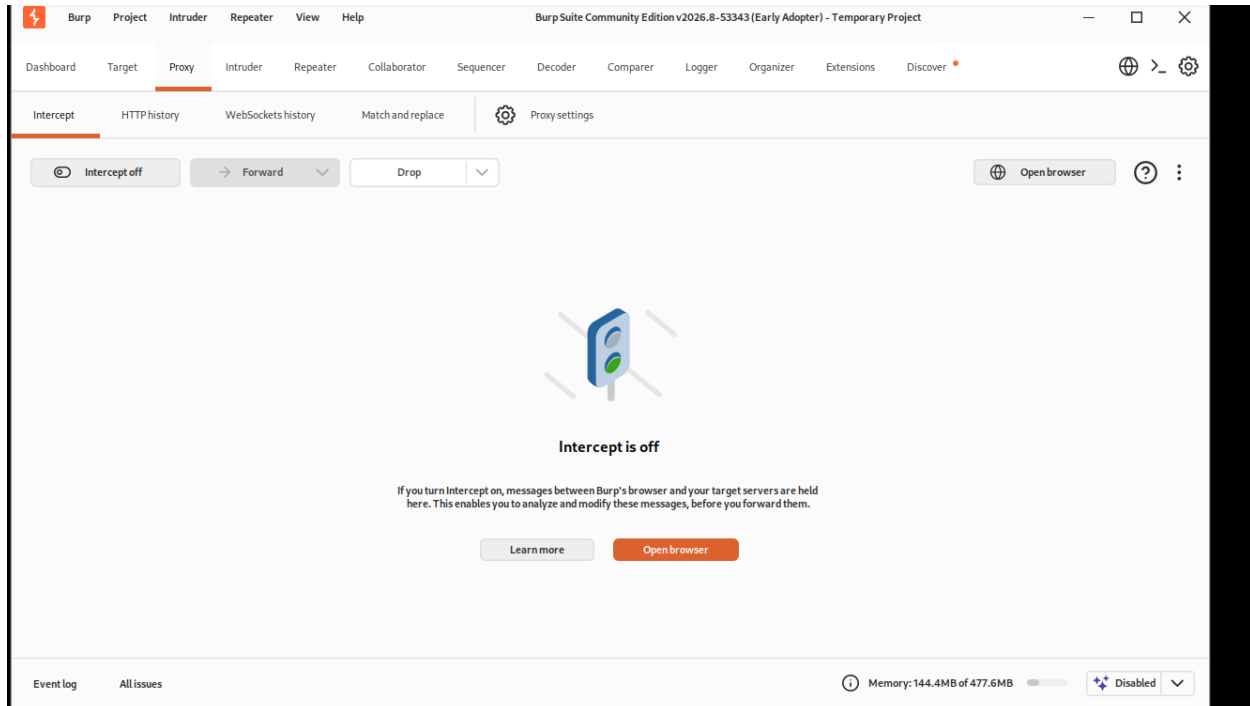


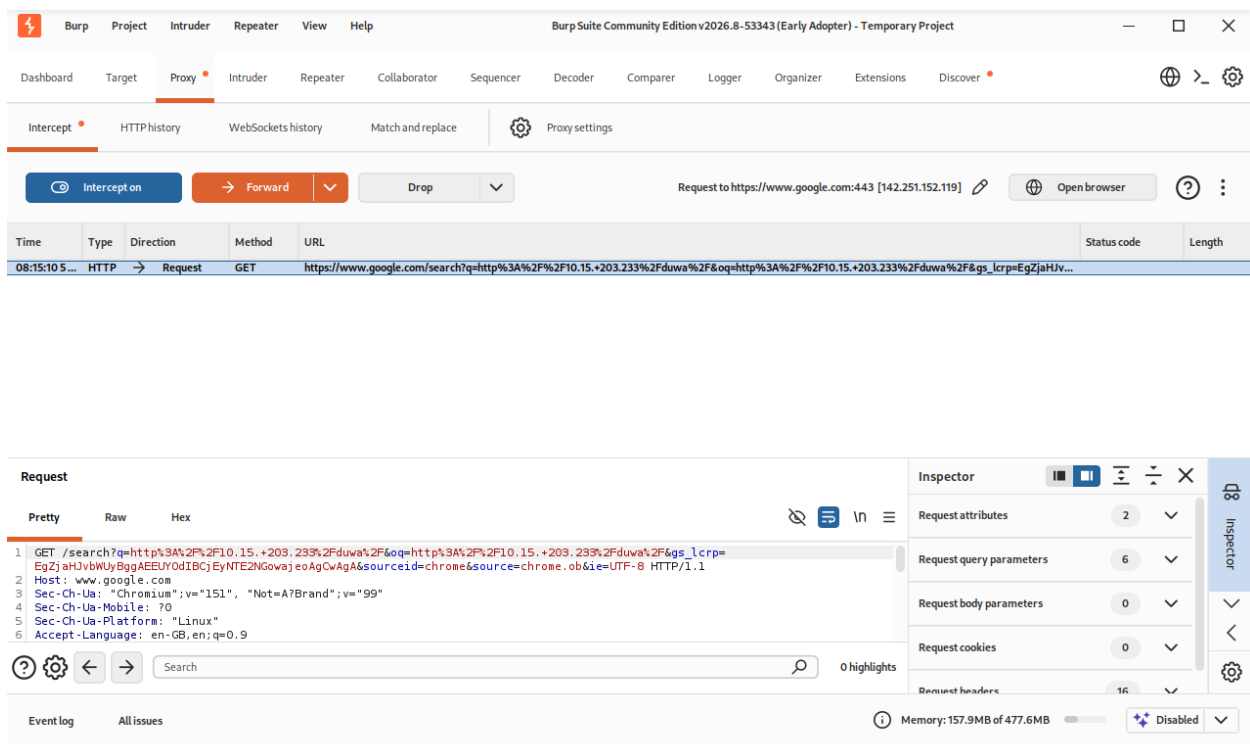
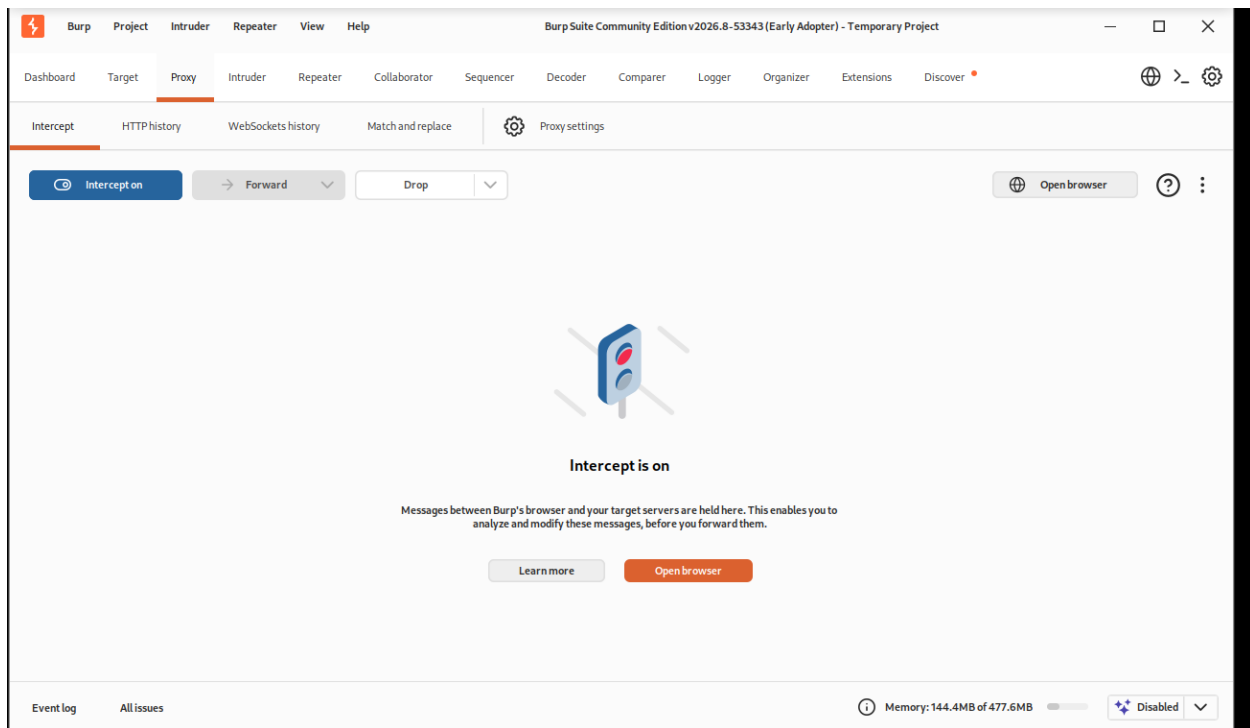


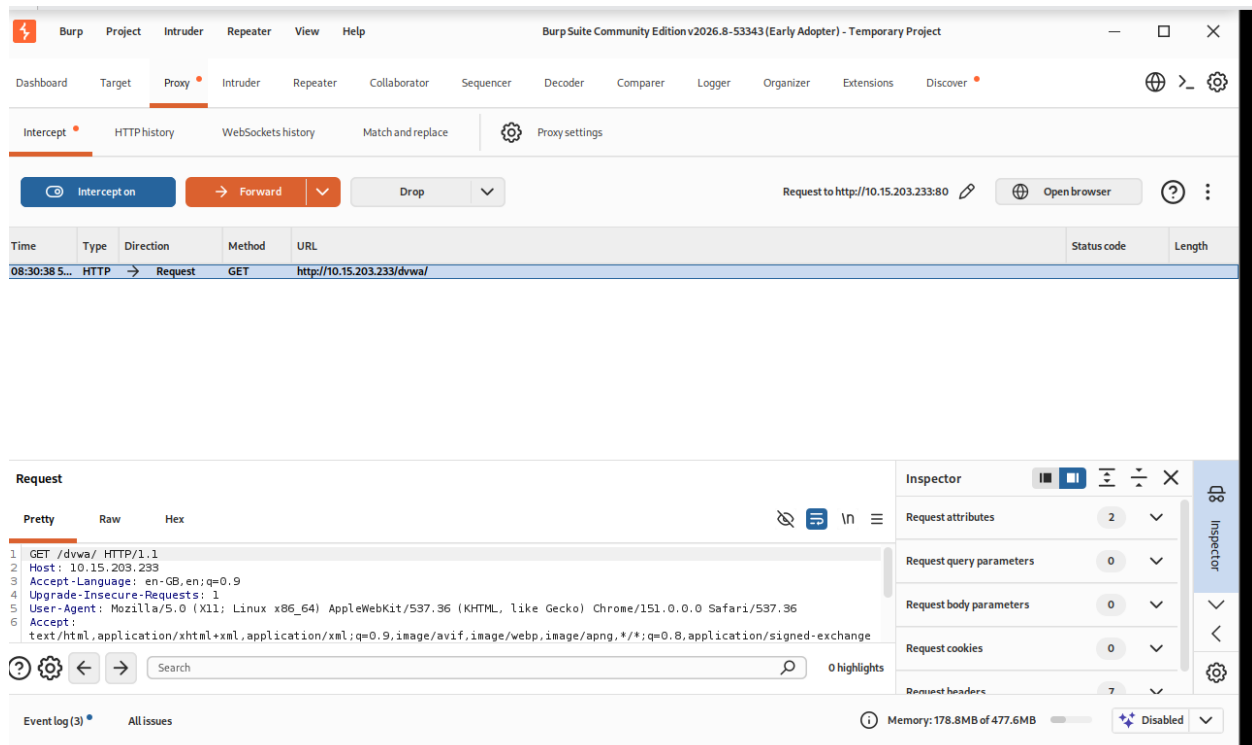
REPORT

The built-in Burp Browser was launched from the Proxy module to simplify interception and avoid browser proxy configuration issues. The browser was automatically configured to route traffic through Burp Suite, ensuring that requests and responses could be captured without additional setup. Using the Burp Browser reduces configuration errors and provides a controlled environment for web application testing. The browser was successfully opened and connected to Burp Suite, making it ready for traffic inspection. This browser was used for the remaining Burp Suite activities in the exercise.

Step 7: Intercept a Harmless Request



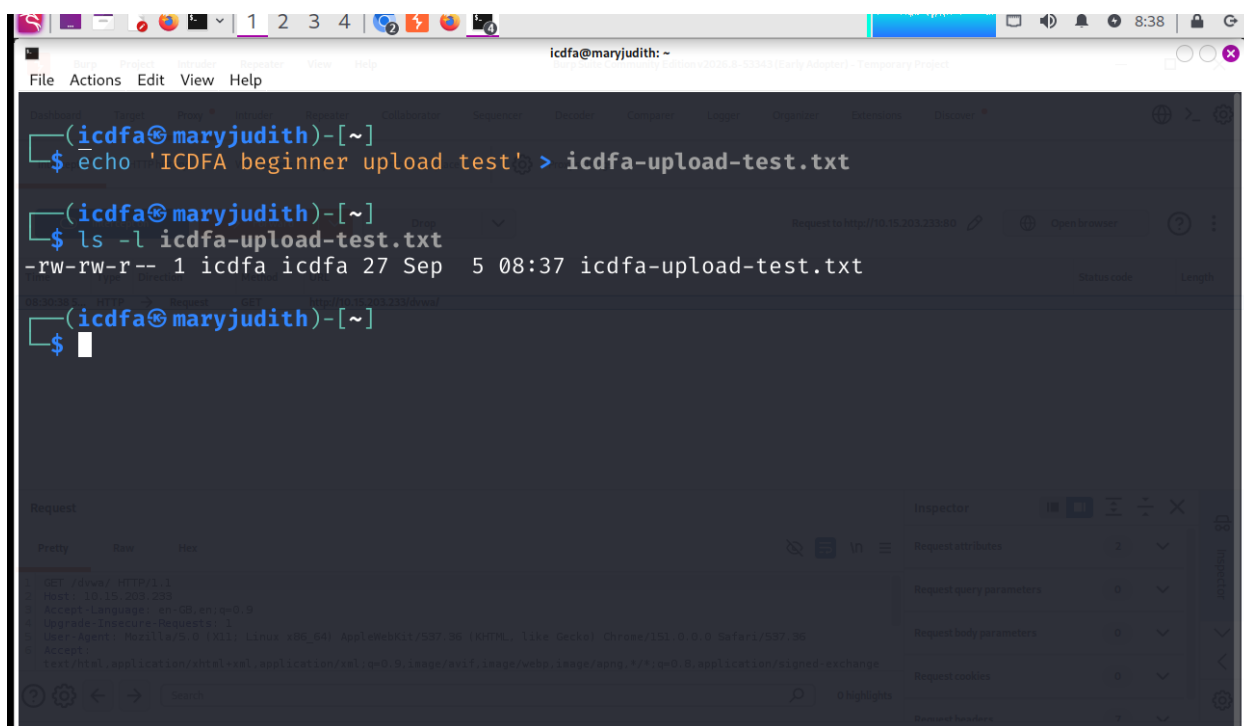




REPORT

Burp Suite was configured to intercept HTTP traffic between the browser and the DVWA application. After enabling interception and browsing to the DVWA URL, a normal GET request was successfully captured before being forwarded to the server. The intercepted request showed important HTTP components including the request method, request path, Host header, and User-Agent header. Examining the request provided a better understanding of how browsers communicate with web applications and how information is transmitted through HTTP. After reviewing the captured request, it was forwarded, allowing the DVWA page to load normally in the browser.

Step 8: Create a Harmless File



The screenshot shows a Kali Linux terminal window and a web browser. In the terminal, the user 'icdfa@maryjudith' has created a file named 'icdfa-upload-test.txt' containing the text 'ICDFA beginner upload test!'. The file's permissions are shown as '-rw-rw-r--'. The web browser shows a request to 'http://10.10.203.233:80' with a status of 200 OK. The request details are visible in the 'Request' tab, showing a GET request for '/index HTTP/1.1' with various headers including 'Host: 10.10.203.233', 'Accept-Language: en-GB,en;q=0.9', 'Upgrade-Insecure-Requests: 1', and 'User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36'.

```
(icdfa@maryjudith)-[~]
$ echo 'ICDFA beginner upload test!' > icdfa-upload-test.txt

(icdfa@maryjudith)-[~]
$ ls -l icdfa-upload-test.txt
-rw-rw-r-- 1 icdfa icdfa 27 Sep  5 08:37 icdfa-upload-test.txt

(icdfa@maryjudith)-[~]
$
```

Request to http://10.10.203.233:80

200 OK

Request

Pretty Raw Hex

1 GET /index HTTP/1.1
2 Host: 10.10.203.233
3 Accept-Language: en-GB,en;q=0.9
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,image/png,image/svg+xml;q=0.8,application/signed-exchange;v=b3;q=0.4

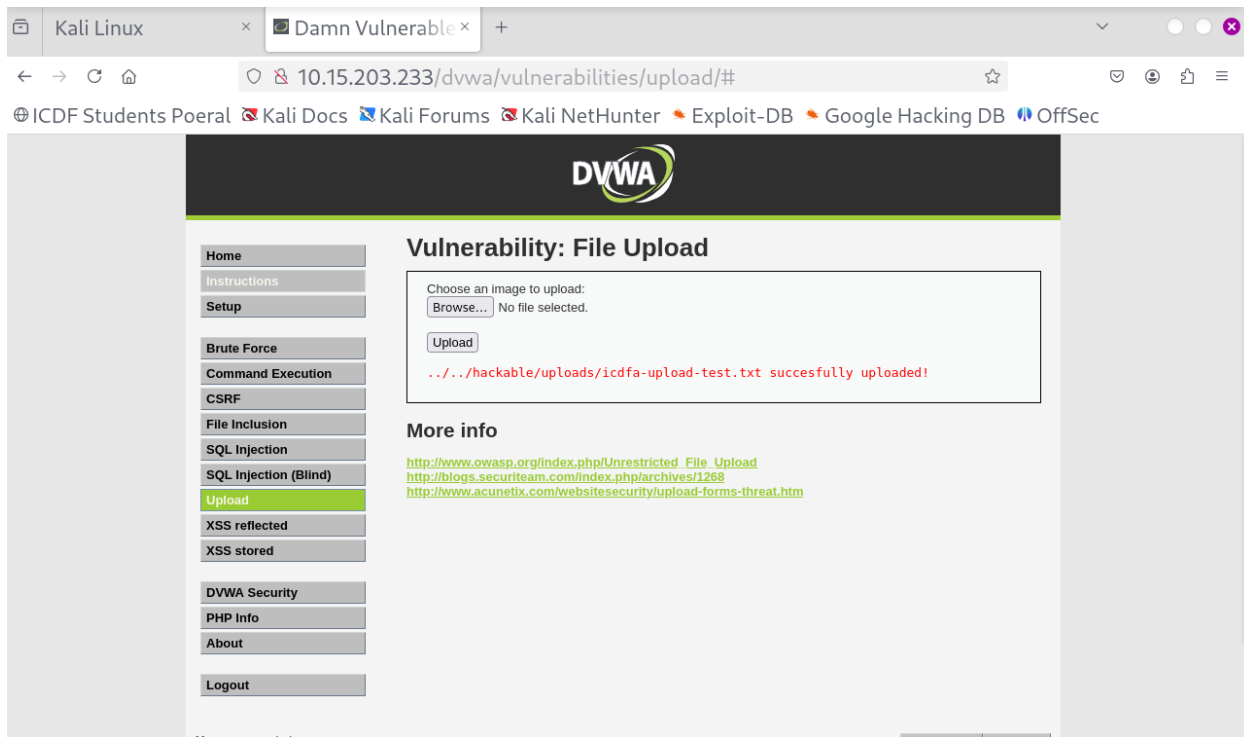
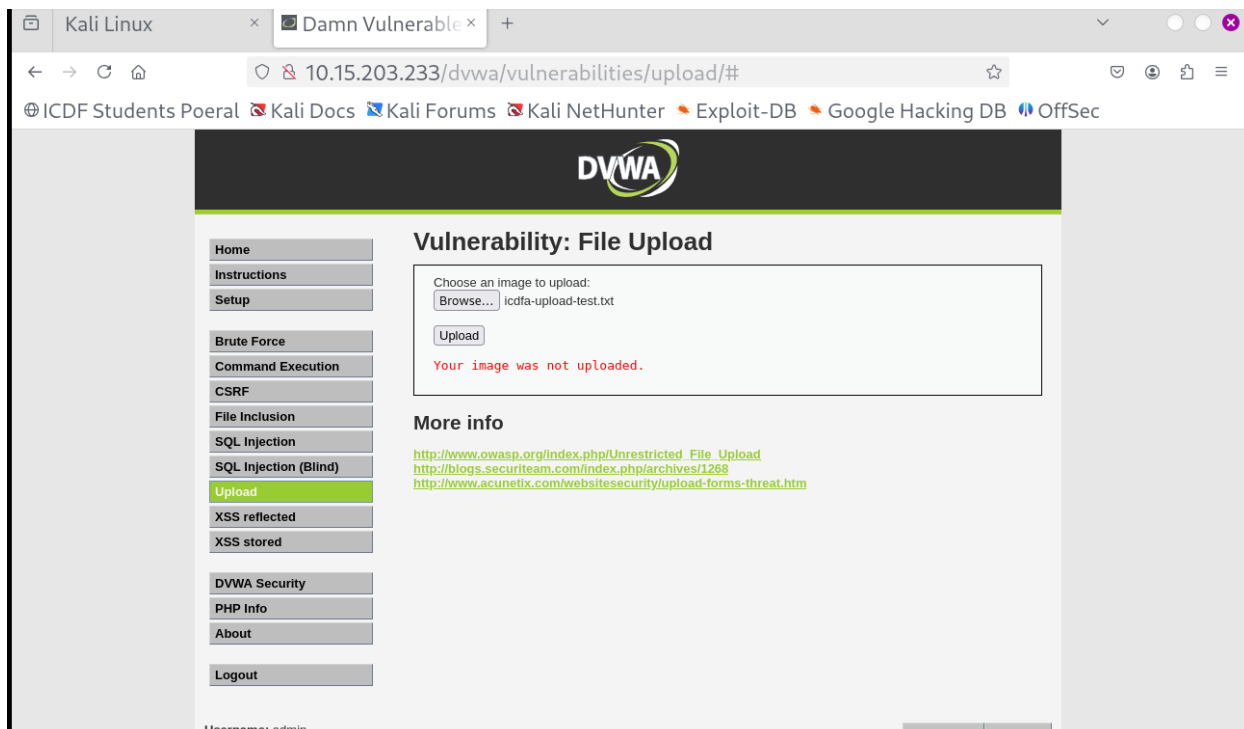
Inspector

Request attributes 2
Request query parameters 0
Request body parameters 0
Request cookies 0
Request headers 1

Report

A harmless text file was created on the Kali Linux system to be used for file upload testing within DVWA. The file contained only simple text content and did not include any executable code or potentially harmful data. Creating a safe test file ensured that the upload functionality could be examined without introducing security risks to the laboratory environment. After creation, the file was verified using the `ls -l` command to confirm its existence, filename, and size. This file served as the baseline upload object for subsequent file validation experiments within the application.

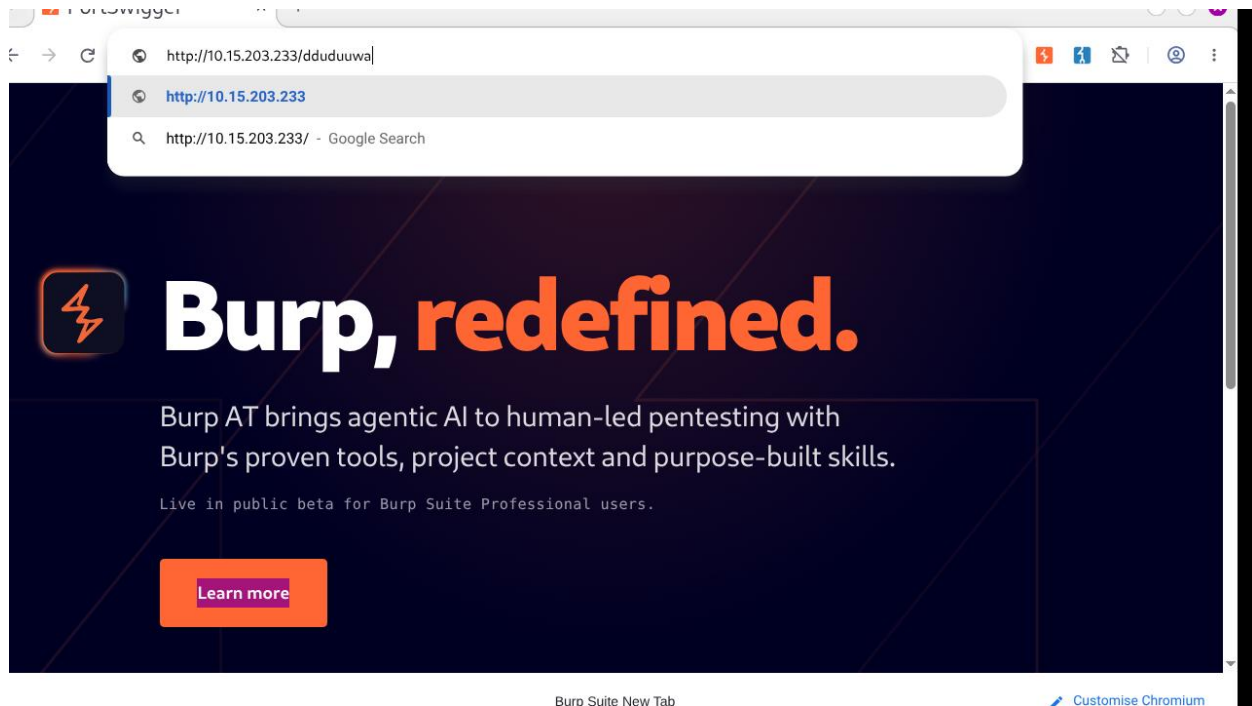
Step 10: Normal Upload

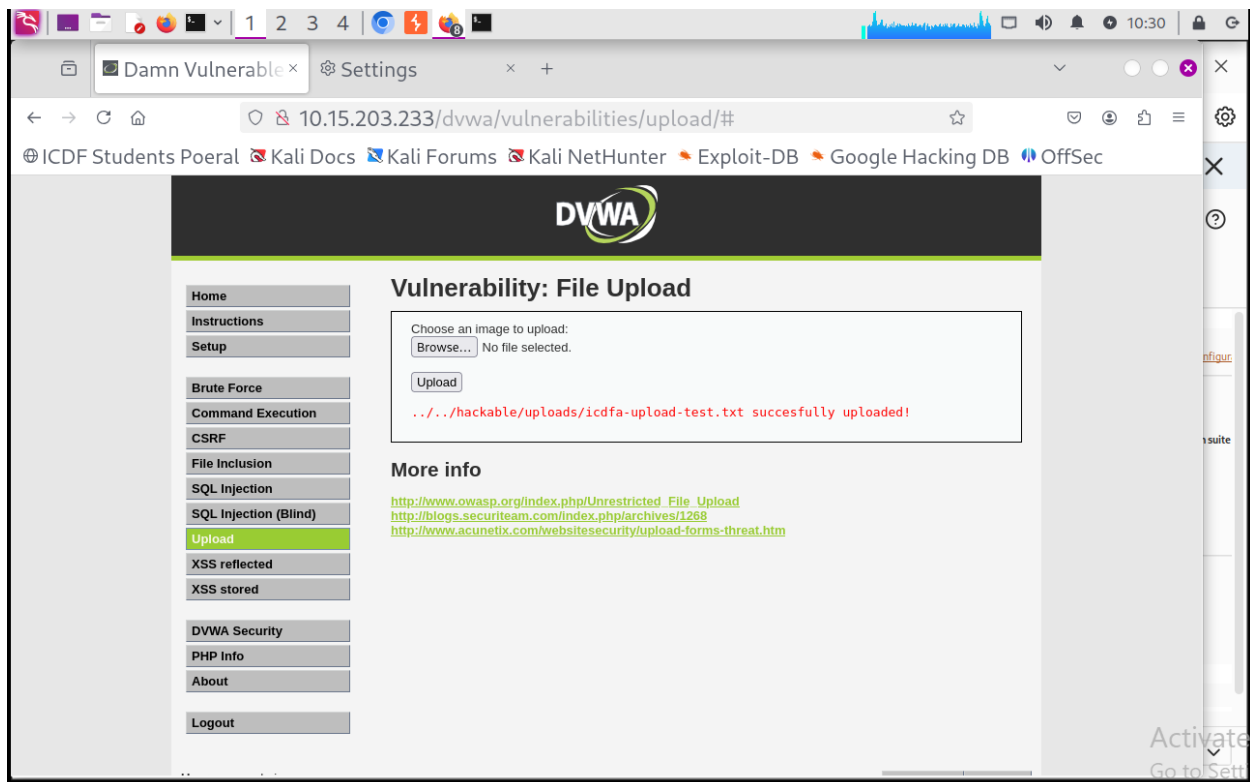


REPORT

A normal upload test was performed using the harmless text file `icdfa-upload-test.txt`. The file was selected through the DVWA File Upload form and submitted without modifying any part of the request. The application processed the upload and returned a response indicating the outcome of the operation. This step established a baseline for understanding how the application handles standard file uploads before conducting additional validation tests. The result of this upload will later be compared with tests involving different file extensions and modified MIME types.

Step 11: Intercept Upload Request

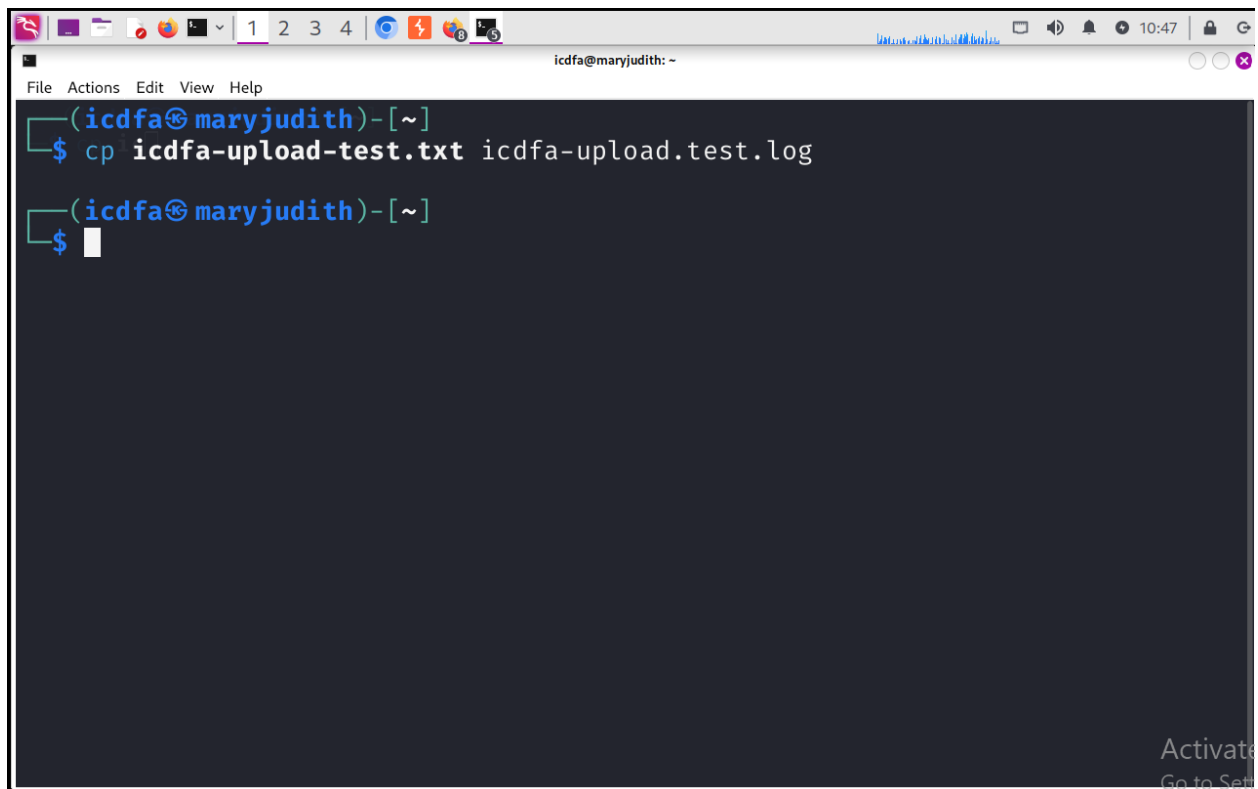




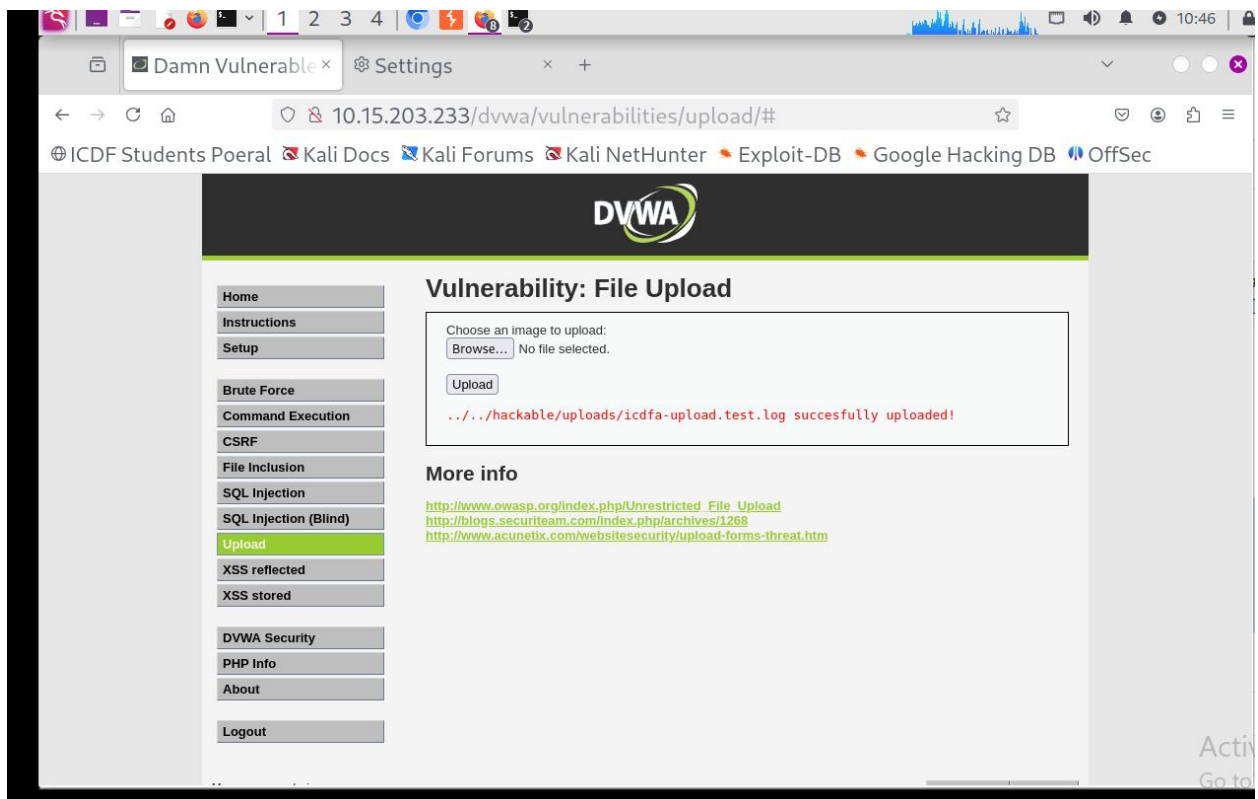
REPORT

The file upload process was examined using Burp Suite to understand how uploaded files are transmitted to a web application. The upload request was observed as an HTTP POST request containing multipart form data. The request included the uploaded filename, the form field responsible for the upload, and the client-supplied MIME type. This demonstrated how browsers package file data and metadata together before sending the request to the server. The exercise provided insight into how file upload mechanisms function and why server-side validation is necessary.

Step 12: Extension Handling



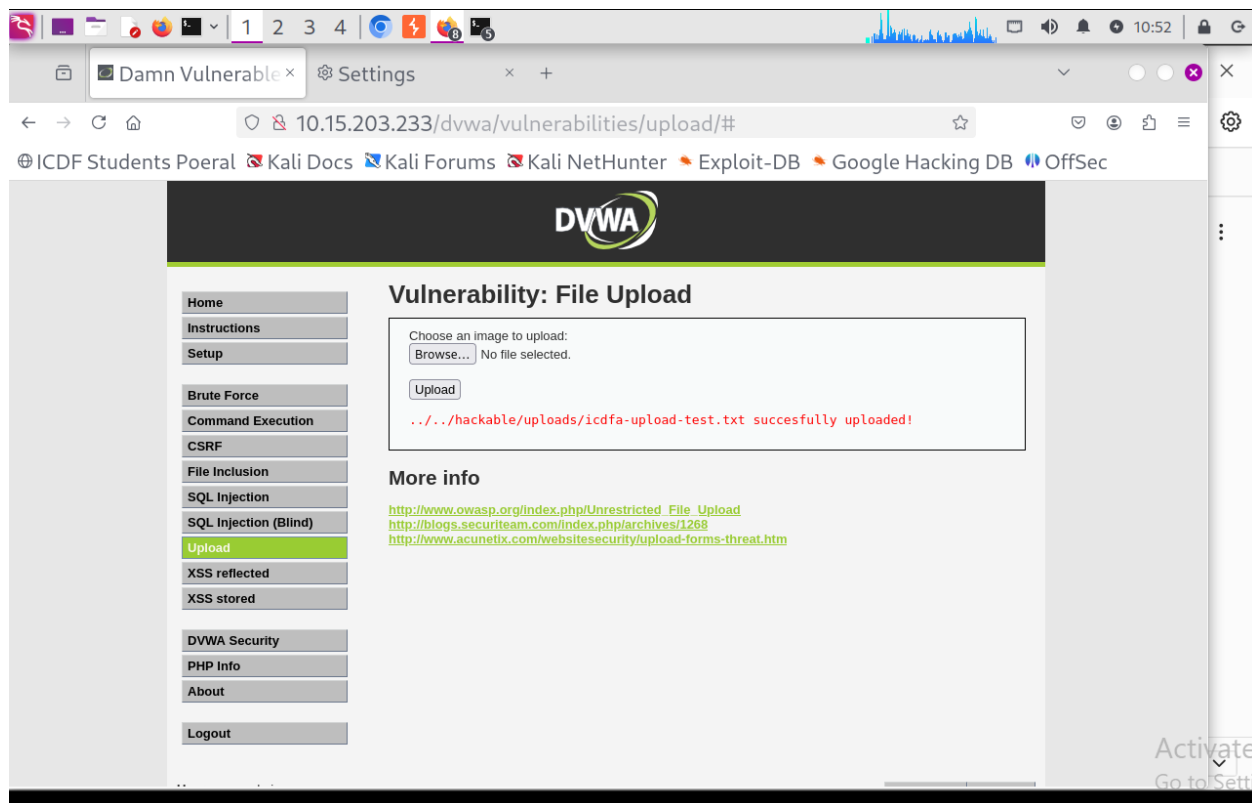
A terminal window titled 'icdfa@maryjudith: ~' with a menu bar (File, Actions, Edit, View, Help). The terminal shows the command `cp icdfa-upload-test.txt icdfa-upload.test.log` being executed. The prompt is `(icdfa@maryjudith)-[~]`. The terminal output shows the command was executed successfully, and the prompt is now `$`.



REPORT

A file extension validation test was performed by creating a copy of the original text file and changing its extension from .txt to .log. The content of the file remained unchanged, ensuring that only the filename extension differed. The modified file, icdfa-upload-test.log, was uploaded through the DVWA File Upload module. The application accepted the file and displayed a successful upload message, indicating that the file extension alone was not being strictly validated. This demonstrated that the application's upload controls were permissive and allowed alternative file extensions despite the file containing the same harmless text data.

Step 13: MIME Handling



Burp

Project

Intruder

Repeater

View

Help

Burp Suite Community Edition v2026.8-53343 (Early Adopter) - Temporary Project

Dashboard

Target

Proxy

Intruder

Repeater

Collaborator

Sequencer

Decoder

Comparer

Logger

Organizer

Extensions

Discover

Intercept

HTTP history

WebSockets history

Match and replace

Proxy settings

Filter settings: Hiding CSS and image content; hiding specific extensions

Pro version only

Filter on

	Host	Method	URL	Params	Edited	Status code	Length	MIME ty...	Extension	Title	Notes	TLS	IP	Cookies	Tim
1	https://www.google.com	GET	/search?q=http%3A%2F%2F10.1...	✓		200	94390	HTML		Google Search		✓	142.251.154.119	AEC=AdjVEase...	10:2
2	https://www.google.com	GET	/search?q=http%3A%2F%2F10.1...	✓		302	2397	HTML		302 Moved		✓	142.251.154.119	SG_SS=0; __Sec...	10:3
3	https://www.google.com	GET	/sorry/index?continue=https://w...	✓		429	4231	HTML		https://www.google...		✓	142.251.156.119		10:4
5	https://www.google.com	GET	/recaptcha/enterprise/anchor?ar...	✓		200	56390	HTML		reCAPTCHA		✓	142.251.156.119		10:4
8	https://www.google.com	GET	/recaptcha/enterprise/anchor?ar...	✓		200	56313	HTML		reCAPTCHA		✓	142.251.156.119		10:4
9	https://www.google.com	GET	/recaptcha/enterprise/fallback?k...	✓		200	2304	HTML		reCAPTCHA challenge		✓	142.251.156.119		10:4

Event log

All issues

Memory: 152.0MB of 477.6MB

Disabled

REPORT

The purpose of this test was to demonstrate that the MIME type supplied by the browser can be modified and therefore should not be trusted as a security control. During the exercise, the MIME type associated with the uploaded file was reviewed and compared with the actual file content. A client can easily change the value of the Content-Type header before the request reaches the server, making MIME-based validation unreliable when used alone. Applications that trust only the MIME type supplied by the browser may incorrectly accept files that do not match their declared type. Effective upload validation should therefore include server-side content inspection in addition to MIME type checks.

Step 15: Run Nikto

```
icdfa@maryjudith: ~  
$ nikto -h http://10.15.203.233  
Command 'nikto' not found, but can be installed with:  
sudo apt install nikto  
Do you want to install it? (N/y)y  
sudo apt install nikto  
sudo: unable to resolve host maryjudith: Name or service not known  
The following packages were automatically installed and are no longer required:  
libcaes1 libopenh264-7 python3-libfswi  
libcrypt1t64 libscca1t64 python3-liblnk  
libcrypt-dev libxnnpack0 python3-libmsiecf  
libdnnl3 python3-acstore python3-libolecf  
libevt1t64 python3-cffi python3-libscca  
libevtx1t64 python3-elasticsearch python3-pefile  
libfcgi-bin python3-flor python3-pycaes  
libfswi1t64 python3-libcreg python3-pycparser  
libglapi-mesa python3-libesedb python3-zstd
```

```
libglapi-mesa python3-libesedb python3-zstd  
libmsiecf1t64 python3-libevt rpcsvc-proto  
libolecf1 python3-libevtx  
Use 'sudo apt autoremove' to remove them.  
  
Upgrading:  
dpkg libjson-xs-perl  
dpkg-dev liblocale-gettext-perl  
libalgorithm-diff-xs-perl libnet-dbus-perl  
libapt-pkg-perl libnet-dns-sec-perl  
libc-bin libnet-libidn2-perl  
libc-dev-bin libnet-ssleay-perl  
libc-l10n libsocket6-perl  
libc6 libstring-crc32-perl  
libc6:i386 libtext-charwidth-perl  
libc6-dev libtext-iconv-perl  
libclone-perl libwin-hivex-perl  
libcommon-sense-perl libxml-parser-perl  
libdpkg-perl libxml2-utils
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
libc-gconv-modules-extra      libxml-sax-base-perl  
libc-gconv-modules-extra:i386 libxml-sax-expat-perl  
libdigest-perl-md5-perl      libxml-sax-perl  
libperl5.42                  libxml-writer-perl  
libwhisker2-perl             libxml2-16  
libxml-libxml-perl           perl-modules-5.42  
  
Suggested packages:  
  libxml-sax-expatxs-perl  
  
Recommended packages:  
  apt  
  
Summary:  
  Upgrading: 36, Installing: 15, Removing: 0, Not Upgrading: 2599  
  Download size: 33.2 MB  
  Space needed: 61.5 MB / 3,454 MB available  
  
Continue? [Y/n] ☐
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Space needed: 61.5 MB / 3,454 MB available  
  
Continue? [Y/n] y  
Get:1 http://http.kali.org/kali kali-rolling/main amd64 dpkg amd64  
1.23.7+kali1 [1,533 kB]  
Get:2 http://kali.download/kali kali-rolling/main i386 libc-gconv-m  
odules-extra i386 2.43-4 [1,097 kB]  
Get:3 http://kali.download/kali kali-rolling/main amd64 libc-l10n a  
ll 2.43-4 [750 kB]  
Get:4 http://kali.download/kali kali-rolling/main amd64 locales all  
2.43-4 [3,911 kB]  
Get:5 http://kali.download/kali kali-rolling/main i386 libc6 i386 2  
.43-4 [1,736 kB]  
Get:6 http://kali.download/kali kali-rolling/main amd64 libc-gconv-  
modules-extra amd64 2.43-4 [1,101 kB]  
Get:7 http://kali.download/kali kali-rolling/main amd64 libc6 amd64  
2.43-4 [1,866 kB]  
Get:8 http://kali.download/kali kali-rolling/main amd64 libc-bin am  
d64 2.43-4 [620 kB]
```


File Actions Edit View Help

```
update-perl-sax-parsers: Registering Perl SAX parser XML::LibXML::SAX with priority 50 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up libxml-sax-expat-perl (0.51-3)...
update-perl-sax-parsers: Registering Perl SAX parser XML::SAX::Expat with priority 50 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up nikto (1:2.6.1-0kali1)...
Processing triggers for libc-bin (2.43-4)...
Processing triggers for systemd (257.5-2)...
Processing triggers for man-db (2.13.0-1)...
```

Progress: [99%] [|||||] Activate Go to Settings

PortSwigger icdfa@maryjudith: ~

File Actions Edit View Help

```
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up libxml-sax-expat-perl (0.51-3)...
update-perl-sax-parsers: Registering Perl SAX parser XML::SAX::Expat with priority 50 ...
update-perl-sax-parsers: Updating overall Perl SAX parser modules info file ...
Replacing config file /etc/perl/XML/SAX/ParserDetails.ini with new version
Setting up nikto (1:2.6.1-0kali1)...
Processing triggers for libc-bin (2.43-4)...
Processing triggers for systemd (257.5-2)...
Processing triggers for man-db (2.13.0-1)...
Processing triggers for kali-menu (2025.1.1)...
```

(icdfa@maryjudith)-[~]
\$

More... Settings View Help

Activate Go to Settings


```
icdfa@maryjudith: ~  
$ nikto -h http://10.15.203.233  
- Nikto v2.6.1  
  
+ Target IP: 10.15.203.233  
+ Target Hostname: 10.15.203.233  
+ Target Port: 80  
+ Platform: Unknown  
+ Start Time: 2026-09-05 11:20:37 (GMT1)  
  
+ Server: Apache/2.2.8 (Ubuntu) DAV/2  
+ [000287] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.  
+ [750500] /icons/: Directory indexing found. See: CWE-548  
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.  
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
```

```
e dirs). CGI tests skipped.  
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.  
+ [000434] /: HTTP TRACE method is active and replies which suggest the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross\_Site\_Tracing  
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.  
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: https://exchange.xforce.ibmcloud.com/vulnerabilities/8275  
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.8).  
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.68).  
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
```

```
abases, and should be protected or limited to authorized hosts. See
: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced
  with the Content-Security-Policy HTTP header with the frame-ancest
  ors directive. See: https://developer.mozilla.org/en-US/docs/Web/HT
  TP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This co
  uld allow the user agent to render the content of the site in a dif
  ferent fashion to the MIME type. See: https://www.netsparker.com/we
  b-vulnerability-scanner/vulnerabilities/missing-content-type-header
  /
+ 8235 requests: 0 errors and 31 items reported on the remote host
+ End Time: 2026-09-05 11:21:08 (GMT1) (31 seconds)

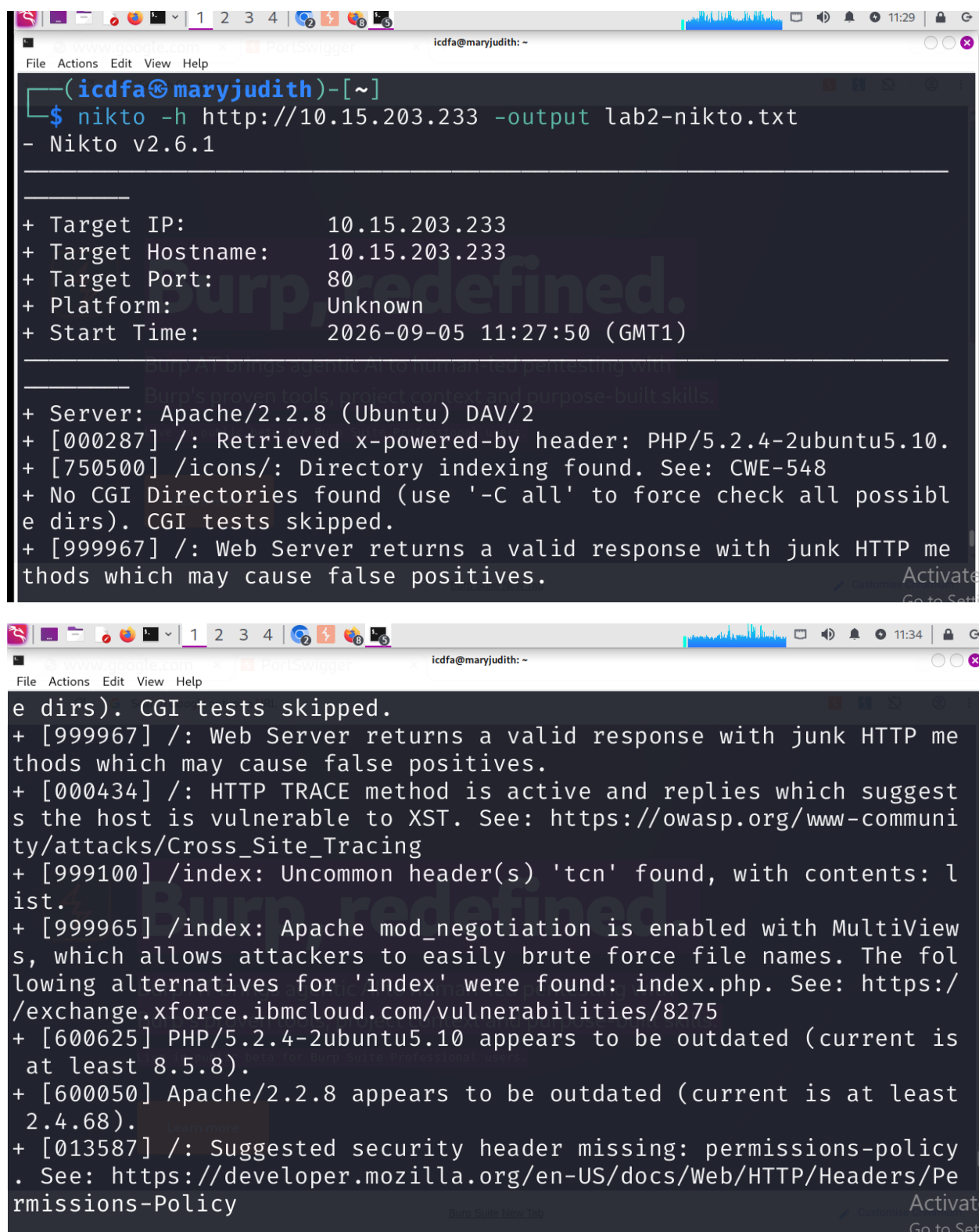
+ 1 host(s) tested

(icdfa@maryjudith)-[~]
$
```

REPORT:

A Nikto scan was conducted against the target web server to identify common web security issues and configuration weaknesses. The scan was executed using the command `nikto -h http://10.15.203.233`. Nikto successfully connected to the server and examined the web application's configuration. Several observations were reported, including potential information disclosure through server responses. The scan also identified files and directories that may be accessible to users. Missing or weak security-related HTTP headers were noted during the assessment. Some findings suggested that default configurations or unnecessary resources could be present on the server. These results should be treated as observations rather than confirmed vulnerabilities until verified manually. The assessment highlighted the importance of proper web server hardening and security configuration. Overall, Nikto provided valuable insight into potential security weaknesses that could assist in improving the web application's security posture.

Step 16: Save Nikto Output



```
(icdfa@maryjudith)-[~]
$ nikto -h http://10.15.203.233 -output lab2-nikto.txt
- Nikto v2.6.1

+ Target IP: 10.15.203.233
+ Target Hostname: 10.15.203.233
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-05 11:27:50 (GMT1)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [000287] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found. See: CWE-548
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.

e dirs). CGI tests skipped.
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggest the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.8).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.68).
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
```

```
nd.
+ [750500] /doc/: Directory indexing found. See: CWE-548
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://nvd.nist.gov/vuln/detail/CVE-1999-0678
+ [001384] /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writesups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writesups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writesups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.detectify.com/writesups/do-you-dare-to-show-your-php-easter-egg/
```

```
+ [002989] /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

+ [006672] /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [007107] /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/writesups/do-you-dare-to-show-your-php-easter-egg/
```

```
ors directive. See: https://developer.mozilla.org/en-US/docs/Web/HT
TP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This co
uld allow the user agent to render the content of the site in a dif
ferent fashion to the MIME type. See: https://www.netsparker.com/we
b-vulnerability-scanner/vulnerabilities/missing-content-type-header
/
+ 8235 requests: 0 errors and 31 items reported on the remote host
+ End Time: 2026-09-05 11:30:43 (GMT1) (173 seconds)

+ 1 host(s) tested

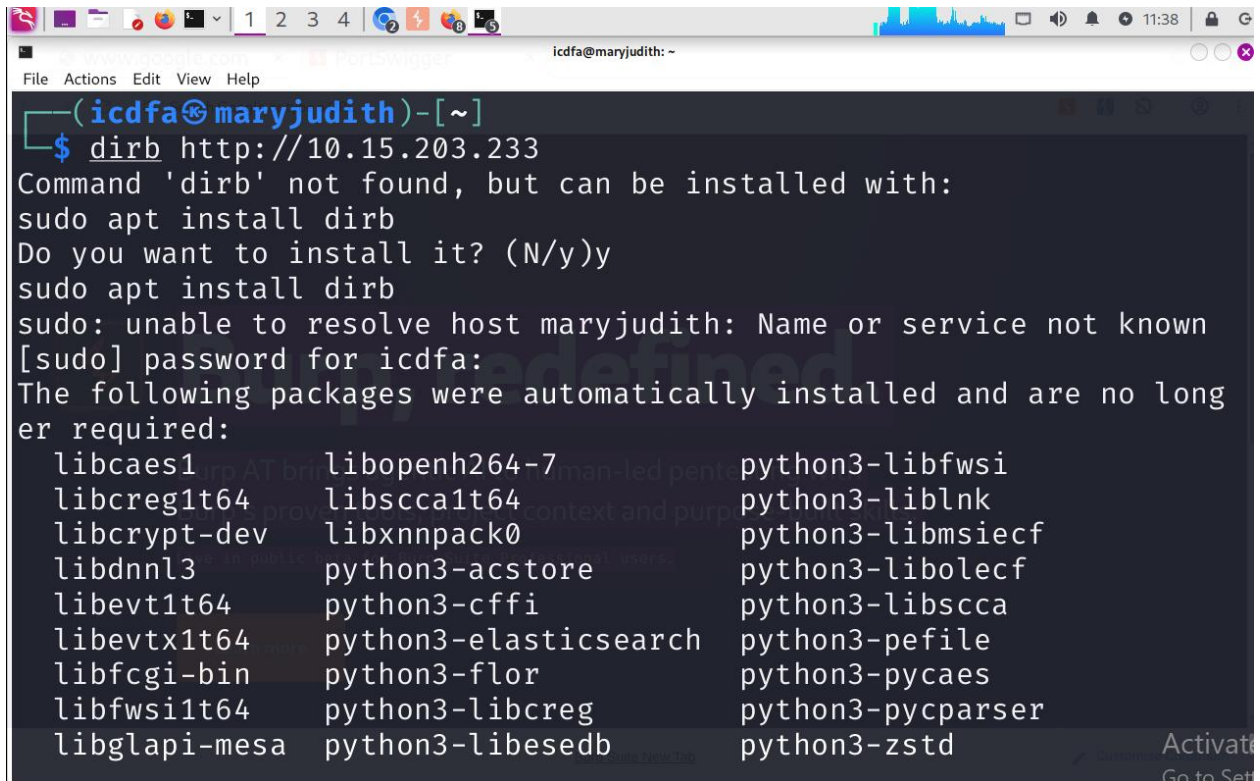
(icdfa@maryjudith)-[~]
$ ls -l lab2-nikto.txt
-rw-rw-r-- 1 icdfa icdfa 4459 Sep  5 11:30 lab2-nikto.txt

(icdfa@maryjudith)-[~]
$
```

Report

The results of the Nikto scan were saved to a file named lab2-nikto.txt for documentation and future review. Saving the output ensured that all findings were preserved as evidence for the assessment. The file contained information about the target web server, configuration observations, and potential security concerns identified during the scan. This approach improved report accuracy by allowing findings to be reviewed after the scan completed. The saved output was included as supporting evidence for the web application security assessment.

Step 17: DIRB



```
(icdfa@maryjudith)-[~]
$ dirb http://10.15.203.233
Command 'dirb' not found, but can be installed with:
sudo apt install dirb
Do you want to install it? (N/y)y
sudo apt install dirb
sudo: unable to resolve host maryjudith: Name or service not known
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
  libcaes1      libopenh264-7      python3-libfws1
  libcreg1t64   libssca1t64        python3-liblnk
  libcrypt-dev  libxnnpack0        python3-libmsiecf
  libdnnl3      python3-acstore     python3-libolecf
  libevt1t64    python3-cffi        python3-libssca
  libevtx1t64   python3-elasticsearch python3-pefile
  libfcgi-bin   python3-flor        python3-pycaes
  libfws1t64    python3-libcreg     python3-pycparser
  libglapi-mesa python3-libesedb     python3-zstd
```

```
libglapi-mesa python3-libesdb python3-zstd
libmsiecf1t64 python3-libevt rpcsvc-proto
libolecf1 python3-libevtx
Use 'sudo apt autoremove' to remove them.

Installing:
  dirb

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2599
  Download size: 208 kB
  Space needed: 1,511 kB / 3,379 MB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 dirb amd64
2.22+dfsg-7 [208 kB]
Fetched 208 kB in 2s (87.9 kB/s)
Selecting previously unselected package dirb.
(Reading database... 422135 files and directories currently installed
.)
```

```
Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2599
  Download size: 208 kB
  Space needed: 1,511 kB / 3,379 MB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 dirb amd64
2.22+dfsg-7 [208 kB]
Fetched 208 kB in 2s (87.9 kB/s)
Selecting previously unselected package dirb.
(Reading database... 422135 files and directories currently installed
.)
Preparing to unpack .../dirb_2.22+dfsg-7_amd64.deb...
Unpacking dirb (2.22+dfsg-7)...
Setting up dirb (2.22+dfsg-7)...
Processing triggers for man-db (2.13.0-1)...
Processing triggers for kali-menu (2025.1.1)...

(icdfa@maryjudith)-[~]
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Preparing to unpack .../dirb_2.22+dfsg-7_amd64.deb...  
Unpacking dirb (2.22+dfsg-7)...  
Setting up dirb (2.22+dfsg-7)...  
Processing triggers for man-db (2.13.0-1)...  
Processing triggers for kali-menu (2025.1.1)...  
  
icdfa@maryjudith: ~  
$ dirb http://10.15.203.233  
  
DIRB v2.22  
By The Dark Raver  
  
START_TIME: Sat Sep 5 11:42:06 2026  
URL_BASE: http://10.15.203.233/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
  
icdfa@maryjudith: ~  
File Actions Edit View Help  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://10.15.203.233/ ——  
+ http://10.15.203.233/cgi-bin/ (CODE:403|SIZE:294)  
  
=> DIRECTORY: http://10.15.203.233/dav/  
+ http://10.15.203.233/index (CODE:200|SIZE:891)  
+ http://10.15.203.233/index.php (CODE:200|SIZE:891)  
+ http://10.15.203.233/phpinfo (CODE:200|SIZE:48074)  
+ http://10.15.203.233/phpinfo.php (CODE:200|SIZE:48086)  
  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/  
+ http://10.15.203.233/server-status (CODE:403|SIZE:299)
```



```
icdfa@maryjudith: ~  
+ http://10.15.203.233/phpinfo.php (CODE:200|SIZE:48086)  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/  
+ http://10.15.203.233/server-status (CODE:403|SIZE:299)  
=> DIRECTORY: http://10.15.203.233/test/  
=> DIRECTORY: http://10.15.203.233/twiki/  
—— Entering directory: http://10.15.203.233/dav/ ——  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
—— Entering directory: http://10.15.203.233/phpMyAdmin/ ——  
+ http://10.15.203.233/phpMyAdmin/calendar (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/changelog (CODE:200|SIZE:74593)  
+ http://10.15.203.233/phpMyAdmin/ChangeLog (CODE:200|SIZE:40540)
```

```
icdfa@maryjudith: ~  
+ http://10.15.203.233/phpMyAdmin/ChangeLog (CODE:200|SIZE:40540)  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/contrib/  
+ http://10.15.203.233/phpMyAdmin/docs (CODE:200|SIZE:4583)  
+ http://10.15.203.233/phpMyAdmin/error (CODE:200|SIZE:1063)  
+ http://10.15.203.233/phpMyAdmin/export (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)  
+ http://10.15.203.233/phpMyAdmin/import (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/index (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/index.php (CODE:200|SIZE:4145)  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/js/  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/lang/  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/libraries/  
+ http://10.15.203.233/phpMyAdmin/license (CODE:200|SIZE:18011)  
+ http://10.15.203.233/phpMyAdmin/LICENSE (CODE:200|SIZE:18011)  
+ http://10.15.203.233/phpMyAdmin/main (CODE:200|SIZE:4227)
```

```
icdfa@maryjudith: ~
File Actions Edit View Help
+ http://10.15.203.233/phpMyAdmin/LICENSE (CODE:200|SIZE:18011)
+ http://10.15.203.233/phpMyAdmin/main (CODE:200|SIZE:4227)
+ http://10.15.203.233/phpMyAdmin/navigation (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/phpinfo (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpinfo.php (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpmyadmin (CODE:200|SIZE:21389)
+ http://10.15.203.233/phpMyAdmin/print (CODE:200|SIZE:1063)
+ http://10.15.203.233/phpMyAdmin/readme (CODE:200|SIZE:2624)
+ http://10.15.203.233/phpMyAdmin/README (CODE:200|SIZE:2624)
+ http://10.15.203.233/phpMyAdmin/robots (CODE:200|SIZE:26)
+ http://10.15.203.233/phpMyAdmin/robots.txt (CODE:200|SIZE:26)

=> DIRECTORY: http://10.15.203.233/phpMyAdmin/scripts/

=> DIRECTORY: http://10.15.203.233/phpMyAdmin/setup/
+ http://10.15.203.233/phpMyAdmin/sql (CODE:200|SIZE:4145)

=> DIRECTORY: http://10.15.203.233/phpMyAdmin/test/
```

```
icdfa@maryjudith: ~
File Actions Edit View Help
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/setup/
+ http://10.15.203.233/phpMyAdmin/sql (CODE:200|SIZE:4145)

=> DIRECTORY: http://10.15.203.233/phpMyAdmin/test/

=> DIRECTORY: http://10.15.203.233/phpMyAdmin/themes/
+ http://10.15.203.233/phpMyAdmin/TODO (CODE:200|SIZE:235)
+ http://10.15.203.233/phpMyAdmin/webapp (CODE:200|SIZE:6901)

—— Entering directory: http://10.15.203.233/test/ ——

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

—— Entering directory: http://10.15.203.233/twiki/ ——

=> DIRECTORY: http://10.15.203.233/twiki/bin/
+ http://10.15.203.233/twiki/data (CODE:403|SIZE:296)
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
=> DIRECTORY: http://10.15.203.233/twiki/bin/  
+ http://10.15.203.233/twiki/data (CODE:403|SIZE:296)  
+ http://10.15.203.233/twiki/index (CODE:200|SIZE:782)  
+ http://10.15.203.233/twiki/index.html (CODE:200|SIZE:782)  
  
=> DIRECTORY: http://10.15.203.233/twiki/lib/  
+ http://10.15.203.233/twiki/license (CODE:200|SIZE:19440)  
  
=> DIRECTORY: http://10.15.203.233/twiki/pub/  
+ http://10.15.203.233/twiki/readme (CODE:200|SIZE:4334)  
+ http://10.15.203.233/twiki/templates (CODE:403|SIZE:301)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/contrib/ -  
——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
      (Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/js/ ——— Activate  
Go to Settings
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
=> DIRECTORY: http://10.15.203.233/twiki/pub/  
+ http://10.15.203.233/twiki/readme (CODE:200|SIZE:4334)  
+ http://10.15.203.233/twiki/templates (CODE:403|SIZE:301)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/contrib/ -  
——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
      (Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/js/ ———  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
      (Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/lang/ ———  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it. Activate  
Go to Settings
```

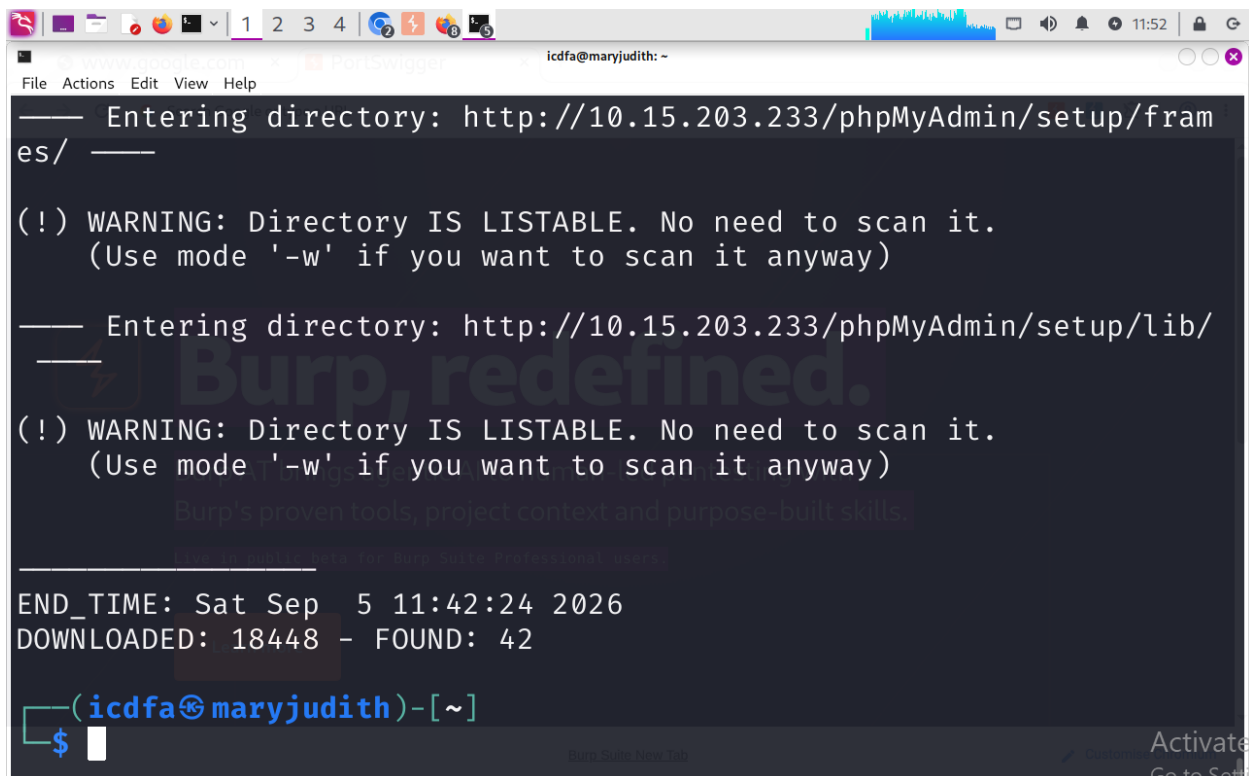
```
icdfa@maryjudith: ~  
File Actions Edit View Help  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
— Entering directory: http://10.15.203.233/phpMyAdmin/js/ —  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
— Entering directory: http://10.15.203.233/phpMyAdmin/lang/ —  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
— Entering directory: http://10.15.203.233/phpMyAdmin/libraries/  
—  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
— Entering directory: http://10.15.203.233/phpMyAdmin/setup/ —  
-  
  
+ http://10.15.203.233/phpMyAdmin/setup/config (CODE:303|SIZE:1370)  
  
⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/setup/frames/  
+ http://10.15.203.233/phpMyAdmin/setup/index (CODE:200|SIZE:8617)  
+ http://10.15.203.233/phpMyAdmin/setup/index.php (CODE:200|SIZE:8625)  
  
⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/setup/lib/  
+ http://10.15.203.233/phpMyAdmin/setup/scripts (CODE:200|SIZE:21967)  
+ http://10.15.203.233/phpMyAdmin/setup/styles (CODE:200|SIZE:6218)
```



```
icdfa@maryjudith: ~  
+ http://10.15.203.233/phpMyAdmin/setup/styles (CODE:200|SIZE:6218)  
— Entering directory: http://10.15.203.233/phpMyAdmin/test/ —  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
— Entering directory: http://10.15.203.233/phpMyAdmin/themes/ --  
--  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
— Entering directory: http://10.15.203.233/twiki/bin/ —  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
— Entering directory: http://10.15.203.233/twiki/lib/ —
```

```
icdfa@maryjudith: ~  
— Entering directory: http://10.15.203.233/twiki/pub/ —  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
— Entering directory: http://10.15.203.233/phpMyAdmin/setup/frames/ —  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
— Entering directory: http://10.15.203.233/phpMyAdmin/setup/lib/ —  
—  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)
```



```
— Entering directory: http://10.15.203.233/phpMyAdmin/setup/frames/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://10.15.203.233/phpMyAdmin/setup/lib/ —
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Sat Sep 5 11:42:24 2026
DOWNLOADED: 18448 - FOUND: 42

(icdfa@maryjudith)-[~]
```

REPORT

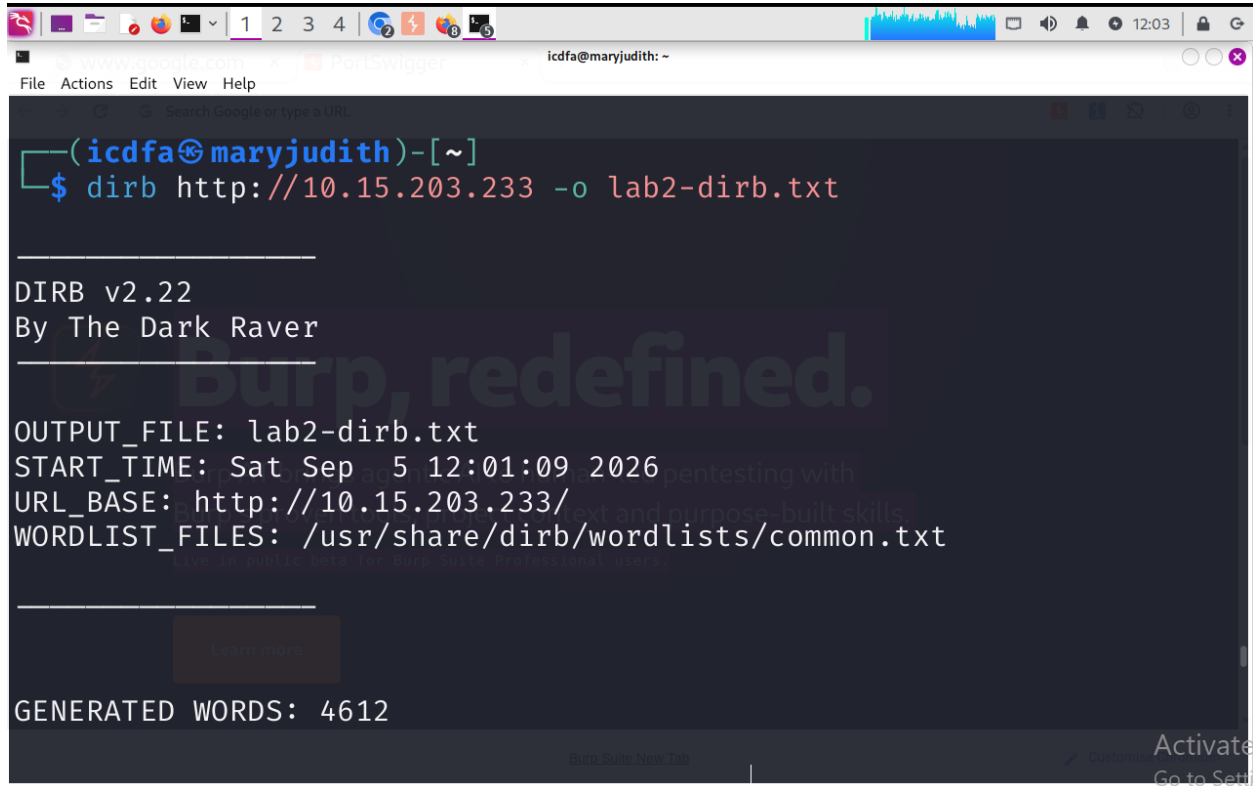
A DIRB scan was performed against the target web server using the command `dirb http://10.15.203.233`. The purpose of the scan was to discover hidden directories, files, and web application resources that may not be directly linked from the main website. DIRB identified several accessible paths and returned different HTTP status codes such as 200, 301, and 403. These results provided insight into the structure of the web application and helped identify potentially sensitive locations. Overall, the scan demonstrated how content discovery tools can assist security testers in understanding the attack surface of a web application.

Step 18: Relate DIRB to Uploads

The DIRB scan results were reviewed to identify directories that could be associated with file storage or upload functionality within the target web application. During the DVWA file upload exercise, uploaded files were successfully stored within the `hackable/uploads` directory, indicating that the application maintains a dedicated location for uploaded content. The directory discovery results were compared with the upload observations to determine whether any discovered paths supported this finding. This analysis helped improve understanding of how the application

organizes and stores uploaded files. The findings also demonstrated why upload directories should be carefully secured to prevent unauthorized access or execution of uploaded content.

Step 19: Save DIRB output



```
(icdfa@maryjudith)-[~]
$ dirb http://10.15.203.233 -o lab2-dirb.txt

____
DIRB v2.22
By The Dark Raver
____
Burp, redefined.
OUTPUT_FILE: lab2-dirb.txt
START_TIME: Sat Sep 5 12:01:09 2026
URL_BASE: http://10.15.203.233/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

____
Learn more
GENERATED WORDS: 4612
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Search Google or type a URL  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://10.15.203.233/ ——  
  
+ http://10.15.203.233/cgi-bin/ (CODE:403|SIZE:294)  
  
⇒ DIRECTORY: http://10.15.203.233/dav/  
+ http://10.15.203.233/index (CODE:200|SIZE:891)  
+ http://10.15.203.233/index.php (CODE:200|SIZE:891)  
+ http://10.15.203.233/phpinfo (CODE:200|SIZE:48074)  
+ http://10.15.203.233/phpinfo.php (CODE:200|SIZE:48086)  
  
⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/  
+ http://10.15.203.233/server-status (CODE:403|SIZE:299)  
  
⇒ DIRECTORY: http://10.15.203.233/test/  
  
⇒ DIRECTORY: http://10.15.203.233/twiki/
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Search Google or type a URL  
⇒ DIRECTORY: http://10.15.203.233/twiki/  
  
—— Entering directory: http://10.15.203.233/dav/ ——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
(Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/ ——  
  
+ http://10.15.203.233/phpMyAdmin/calendar (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/changelog (CODE:200|SIZE:74593)  
+ http://10.15.203.233/phpMyAdmin/ChangeLog (CODE:200|SIZE:40540)  
  
⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/contrib/  
+ http://10.15.203.233/phpMyAdmin/docs (CODE:200|SIZE:4583)  
+ http://10.15.203.233/phpMyAdmin/error (CODE:200|SIZE:1063)  
+ http://10.15.203.233/phpMyAdmin/export (CODE:200|SIZE:4145)  
+ http://10.15.203.233/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)
```



```
1 2 3 4 5
www.google.com PortSwigger icdfa@maryjudith: ~
File Actions Edit View Help
+ http://10.15.203.233/phpMyAdmin/error (CODE:200|SIZE:1063)
+ http://10.15.203.233/phpMyAdmin/export (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/favicon.ico (CODE:200|SIZE:18902)
+ http://10.15.203.233/phpMyAdmin/import (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/index (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/index.php (CODE:200|SIZE:4145)

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/js/

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/lang/

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/libraries/
+ http://10.15.203.233/phpMyAdmin/license (CODE:200|SIZE:18011)
+ http://10.15.203.233/phpMyAdmin/LICENSE (CODE:200|SIZE:18011)
+ http://10.15.203.233/phpMyAdmin/main (CODE:200|SIZE:4227)
+ http://10.15.203.233/phpMyAdmin/navigation (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/phpinfo (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpinfo.php (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpmyadmin (CODE:200|SIZE:21389)
```

```
1 2 3 4 5
www.google.com PortSwigger icdfa@maryjudith: ~
File Actions Edit View Help
+ http://10.15.203.233/phpMyAdmin/navigation (CODE:200|SIZE:4145)
+ http://10.15.203.233/phpMyAdmin/phpinfo (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpinfo.php (CODE:200|SIZE:0)
+ http://10.15.203.233/phpMyAdmin/phpmyadmin (CODE:200|SIZE:21389)
+ http://10.15.203.233/phpMyAdmin/print (CODE:200|SIZE:1063)
+ http://10.15.203.233/phpMyAdmin/readme (CODE:200|SIZE:2624)
+ http://10.15.203.233/phpMyAdmin/README (CODE:200|SIZE:2624)
+ http://10.15.203.233/phpMyAdmin/robots (CODE:200|SIZE:26)
+ http://10.15.203.233/phpMyAdmin/robots.txt (CODE:200|SIZE:26)

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/scripts/

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/setup/
+ http://10.15.203.233/phpMyAdmin/sql (CODE:200|SIZE:4145)

⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/test/

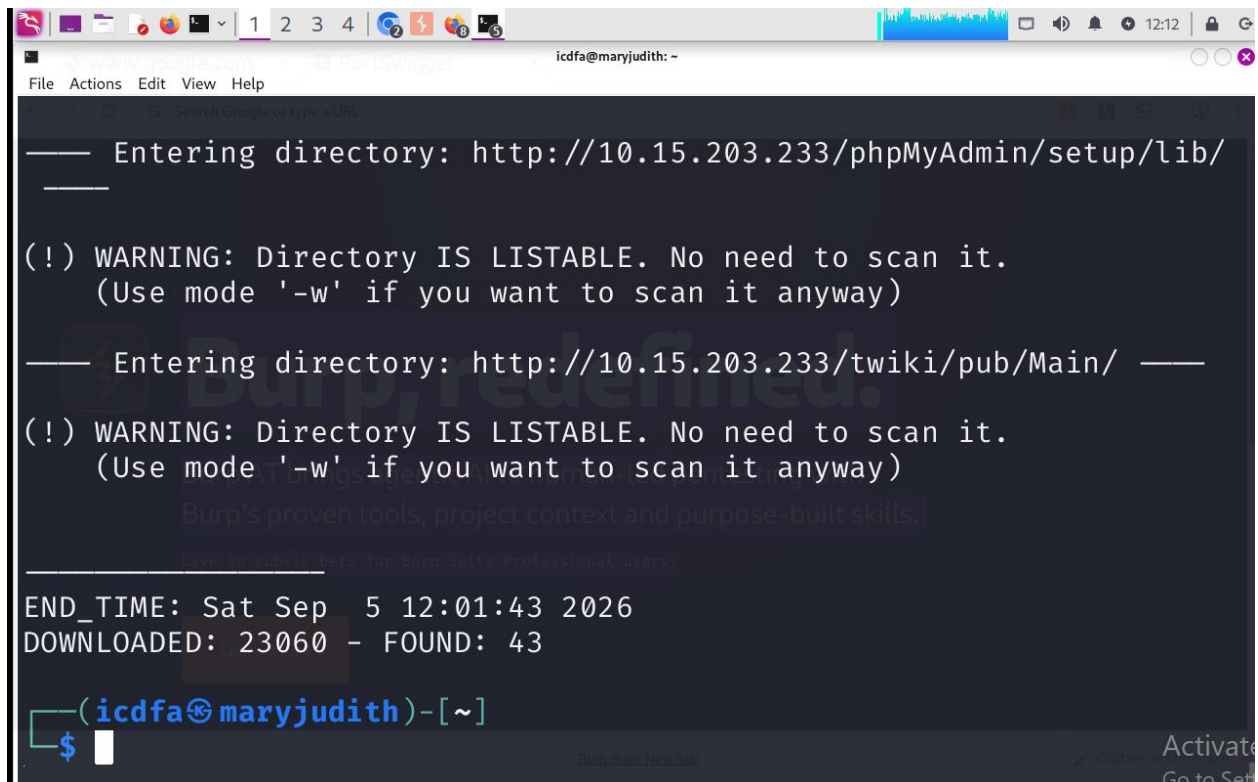
⇒ DIRECTORY: http://10.15.203.233/phpMyAdmin/themes/
+ http://10.15.203.233/phpMyAdmin/TODO (CODE:200|SIZE:235)
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
=> DIRECTORY: http://10.15.203.233/phpMyAdmin/themes/  
+ http://10.15.203.233/phpMyAdmin/TOD0 (CODE:200|SIZE:235)  
+ http://10.15.203.233/phpMyAdmin/webapp (CODE:200|SIZE:6901)  
  
—— Entering directory: http://10.15.203.233/test/ ——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/twiki/ ——  
  
=> DIRECTORY: http://10.15.203.233/twiki/bin/  
+ http://10.15.203.233/twiki/data (CODE:403|SIZE:296)  
+ http://10.15.203.233/twiki/index (CODE:200|SIZE:782)  
+ http://10.15.203.233/twiki/index.html (CODE:200|SIZE:782)  
  
=> DIRECTORY: http://10.15.203.233/twiki/lib/  
+ http://10.15.203.233/twiki/license (CODE:200|SIZE:19440)
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
+ http://10.15.203.233/twiki/index (CODE:200|SIZE:782)  
+ http://10.15.203.233/twiki/index.html (CODE:200|SIZE:782)  
  
=> DIRECTORY: http://10.15.203.233/twiki/lib/  
+ http://10.15.203.233/twiki/license (CODE:200|SIZE:19440)  
  
=> DIRECTORY: http://10.15.203.233/twiki/pub/  
+ http://10.15.203.233/twiki/readme (CODE:200|SIZE:4334)  
+ http://10.15.203.233/twiki/templates (CODE:403|SIZE:301)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/contrib/ ——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
  (Use mode '-w' if you want to scan it anyway)  
  
—— Entering directory: http://10.15.203.233/phpMyAdmin/js/ ——  
  
(!) WARNING: Directory IS LISTABLE. No need to scan it.
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Search Google or type a URL  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/phpMyAdmin/themes/ --  
--  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/twiki/bin/ --  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/twiki/lib/ --  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
Activate  
Go to Set
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
Search Google or type a URL  
(Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/phpMyAdmin/themes/ --  
--  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/twiki/bin/ --  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/twiki/lib/ --  
(!) WARNING: Directory IS LISTABLE. No need to scan it.  
    (Use mode '-w' if you want to scan it anyway)  
-- Entering directory: http://10.15.203.233/twiki/pub/ --  
Activate  
Go to Set
```



```
— Entering directory: http://10.15.203.233/phpMyAdmin/setup/lib/
—

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

— Entering directory: http://10.15.203.233/twiki/pub/Main/ —
—

(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

Burp's proven tools, project context and purpose-built skills.
Live in public beta for Burp Suite Professional users.

END_TIME: Sat Sep 5 12:01:43 2026
DOWNLOADED: 23060 - FOUND: 43

(icdfa@maryjudith)-[~]
$
```

REPORT

After completing the DIRB content discovery scan, the results were saved to a text file to preserve the findings for documentation and future analysis. The scan successfully examined the target web application and identified a total of 43 accessible resources and directories. Saving the output ensured that all discovered paths and HTTP responses could be reviewed later without rerunning the scan. The saved report provided supporting evidence for the content discovery phase of the assessment and helped maintain accurate records of the identified web resources. The successful completion of the scan and preservation of the results confirmed that the DIRB findings were available for inclusion in the final laboratory report.

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
10.15.203.233/dvwa/  
(icdfa@maryjudith)-[~]  
$ ip addr  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:cd:75:ad brd ff:ff:ff:ff:ff:ff  
    inet 10.234.230.36/24 brd 10.234.230.255 scope global dynamic noprefixroute eth0  
        valid_lft 2231sec preferred_lft 2231sec  
    inet6 fe80::20c:29ff:fedc:75ad/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(icdfa@maryjudith)-[~]  
$ ping -c 4 10.234.230.36  
PING 10.234.230.36 (10.234.230.36) 56(84) bytes of data.  
64 bytes from 10.234.230.36: icmp_seq=1 ttl=64 time=0.040 ms  
64 bytes from 10.234.230.36: icmp_seq=2 ttl=64 time=0.070 ms  
64 bytes from 10.234.230.36: icmp_seq=3 ttl=64 time=0.044 ms  
64 bytes from 10.234.230.36: icmp_seq=4 ttl=64 time=0.044 ms
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
10.15.203.233/dvwa/  
(icdfa@maryjudith)-[~]  
$ ip addr  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 00:0c:29:cd:75:ad brd ff:ff:ff:ff:ff:ff  
    inet 10.234.230.36/24 brd 10.234.230.255 scope global dynamic noprefixroute eth0  
        valid_lft 2231sec preferred_lft 2231sec  
    inet6 fe80::20c:29ff:fedc:75ad/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(icdfa@maryjudith)-[~]  
$ ping -c 4 10.234.230.36  
PING 10.234.230.36 (10.234.230.36) 56(84) bytes of data.  
64 bytes from 10.234.230.36: icmp_seq=1 ttl=64 time=0.040 ms  
64 bytes from 10.234.230.36: icmp_seq=2 ttl=64 time=0.070 ms  
64 bytes from 10.234.230.36: icmp_seq=3 ttl=64 time=0.044 ms  
64 bytes from 10.234.230.36: icmp_seq=4 ttl=64 time=0.044 ms  
  
— 10.234.230.36 ping statistics —  
4 packets transmitted, 4 received, 0% packet loss, time 3076ms  
rtt min/avg/max/mdev = 0.040/0.049/0.070/0.011 ms  
(icdfa@maryjudith)-[~]  
$
```


Step 21: Identify User-Controlled Inputs

The screenshot shows the Mutillidae web application running on Kali Linux. The browser address bar displays `10.234.230.91/mutillidae/`. The page features a purple header with the title "Mutillidae: Born to be Hacked" and a red bug icon. Below the header, a status bar indicates "Version: 2.1.19", "Security Level: 0 (Hosed)", "Hints: Disabled (0 - I try harder)", and "Not Logged In". A navigation menu includes links for Home, Login/Register, Toggle Hints, Toggle Security, Reset DB, View Log, and View Captured Data. On the left, a sidebar contains links for Core Controls, OWASP Top 10, Others, Documentation, and Resources. The main content area displays a large box stating "Mutillidae: Deliberately Vulnerable PHP Scripts Of OWASP Top 10". Below this, a section titled "Latest Version / Installation" lists links for Latest Version, Installation Instructions, Usage Instructions, Get rid of those pesky PHP errors, Change Log, and Notes. A text box mentions "Samurai WTF and Backtrack contains all the tools needed or you may build your own collection". Logos for Backtrack and Samurai Web Testing Framework are shown. A sidebar on the left contains a blue globe icon and text: "Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these Mozilla Add-ons".

The screenshot shows the Mutillidae web application login page. The browser address bar displays `10.234.230.91/mutillidae/index.php?page=login.php`. The page features a purple header with the title "Mutillidae: Born to be Hacked" and a red bug icon. Below the header, a status bar indicates "Version: 2.1.19", "Security Level: 0 (Hosed)", "Hints: Disabled (0 - I try harder)", and "Not Logged In". A navigation menu includes links for Home, Login/Register, Toggle Hints, Toggle Security, Reset DB, View Log, and View Captured Data. On the left, a sidebar contains links for Core Controls, OWASP Top 10, Others, Documentation, and Resources. The main content area displays a large box titled "Login". Below the title, a blue arrow points to a "Back" link. A green box contains the text "Please sign-in". Below this, a form with two input fields is shown: "Name" with the value "admin" and "Password" with a masked password "*****". A "Login" button is located below the password field. A link "Dont have an account? Please register here" is displayed below the login button. A sidebar on the left contains a blue globe icon and text: "Site hacked...err...quality-tested with Samurai WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these Mozilla Add-ons".

Kali Linux

10.234.230.91/mutillidae/

10.234.230.91/mutillidae/index.php?page=login.php

ICDF Students Poeral
Kali Docs
Kali Forums
Kali NetHunter
Exploit-DB
Google Hacking DB
OffSec

Error: Failure is always an option and this situation proves it

Line	49
Code	0
File	/var/www/mutillidae/process-login-attempt.php
Message	Error executing query: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'test' at line 1
Trace	#0 /var/www/mutillidae/index.php(96): include() #1 {main}
Diagnostic Information	SELECT * FROM accounts WHERE username='' AND password='test'

Did you [setup/reset the DB?](#)

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 148
Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 254
Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 255
Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 256


Mutillidae: Born to be Hacked
Activate

Report

The Mutillidae application was examined to identify locations where users can provide input to the application. User-controlled fields were observed within the Login/Register functionality and other application forms. These inputs allow users to supply data that is processed by the application and may influence application behavior. Identifying user-controlled inputs is important because they represent potential targets for input validation and security testing. The identified inputs were documented for use during subsequent SQL injection assessment activities.

Inputs Identified

Page	Parameter	Method	Normal Value
Login/Register	username	POST	admin
Login/Register	password	POST	password

Login/Register	login form field	POST	user supplied
----------------	------------------	------	---------------

Step 23

Kali Linux x 10.234.230.91/mutillidae/index.php?page=login.php

ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

mutillidae/index.php on line 256

Mutillidae: Born to be Hacked

Version: 2.1.19 Security Level: 0 (Hosed) Hints: Disabled (0 - I try harder) Not Logged In

Home Login/Register Toggle Hints Toggle Security Reset DB View Log View Captured Data

Core Controls OWASP Top 10 Others Documentation Resources

Site hacked...err...quality-tested with Samurai, WTF, Backtrack, Firefox, Burp-Suite, Netcat, and these Mozilla Add-ons

Back

Please sign-in

Name Password

Login

Dont have an account? [Please register here](#)

Activat Go to Set

Kali Linux x 10.234.230.91/mutillidae/index.php?page=login.php

ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

Error: Failure is always an option and this situation proves it	
Line	49
Code	0
File	/var/www/mutillidae/process-login-attempt.php
Message	Error executing query: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near 'test' at line 1
Trace	#0 /var/www/mutillidae/index.php(96): include() #1 {main}
Diagnostic Information	SELECT * FROM accounts WHERE username='' AND password='test'
Did you setup/reset the DB?	

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line 148

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line 254

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line 255

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line 256

Mutillidae: Born to be Hacked

Activat

A single quotation mark (') was entered into the username field to test how the application handled special characters commonly used in SQL injection attacks. The application processed the input and returned a response that was compared with the baseline result recorded earlier. Any difference in behavior, error messages, or query processing may indicate that user input is being incorporated into SQL statements without adequate validation. The test helped determine whether the application was vulnerable to input-handling weaknesses. The observed response was recorded as evidence for subsequent SQL injection analysis.

Step 24: Compare True vs False Conditions

Kali Linux10.234.230.91/mutillidae

10.234.230.91/mutillidae/index.php?page=login.php

ICDF Students PoeralKali DocsKali ForumsKali NetHunterExploit-DBGoogle Hacking DBOffSec

Error: Failure is always an option and this situation proves it

Line	49
Code	0
File	/var/www/mutillidae/process-login-attempt.php
Message	Error executing query: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1 OR '1' =1' AND password='test' at line 1
Trace	#0 /var/www/mutillidae/index.php(96): include() #1 {main}
Diagnostic Information	SELECT * FROM accounts WHERE username=" 1 OR '1' =1' AND password='test'

Did you [setup/reset the DB?](#)

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 148

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 254

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 255

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 256

 **Mutillidae: Born to be Hacked**

Activate
Go to Seti

Error: Failure is always an option and this situation proves it

Line	49
Code	0
File	/var/www/mutillidae/process-login-attempt.php
Message	Error executing query: You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version for the right syntax to use near '1 OR '1' =2' AND password='test' at line 1
Trace	#0 /var/www/mutillidae/index.php(96): include() #1 {main}
Diagnostic Information	SELECT * FROM accounts WHERE username='1 OR '1' =2' AND password='test'

[Did you setup/reset the DB?](#)

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 148

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 254

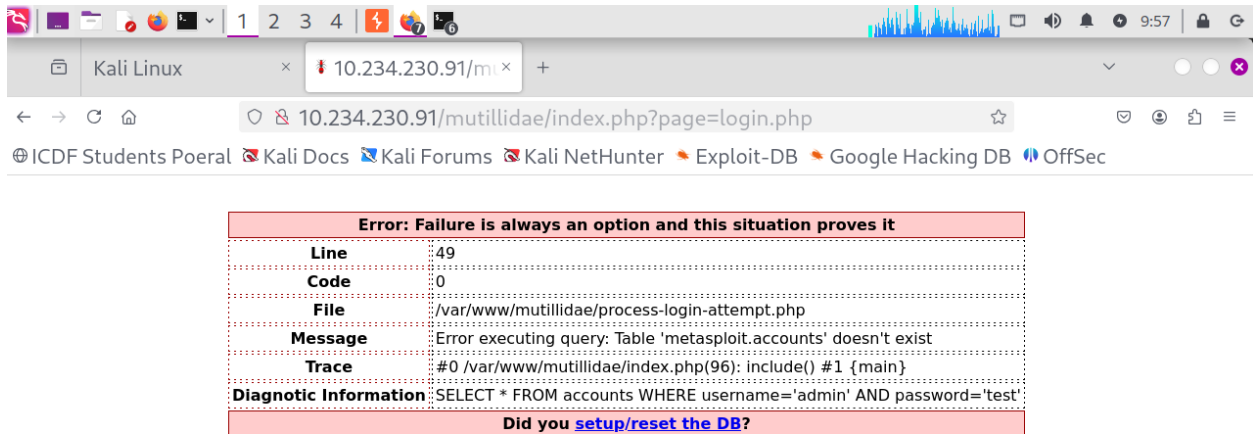
Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 255

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in /var/www/mutillidae/index.php on line 256

REPORT

True and false SQL conditions were submitted through the Mutillidae login form to observe how the application processed user-supplied input. The true condition used the expression ' OR '1'='1, while the false condition used ' OR '1'='2. In both cases, the application returned SQL syntax error messages and displayed diagnostic information, including parts of the SQL query generated by the application. The responses demonstrated that user input was incorporated directly into the SQL statement without proper validation or parameterization. The differing conditions helped illustrate how SQL operators and user-supplied values can influence the structure and behavior of database queries in vulnerable applications.

Step 25: Burp Inspection



The screenshot shows a web browser window with the address bar displaying `10.234.230.91/mutillidae/index.php?page=login.php`. The page content is a red error box with the following text:

Error: Failure is always an option and this situation proves it

Line	49
Code	0
File	/var/www/mutillidae/process-login-attempt.php
Message	Error executing query: Table 'metasploit.accounts' doesn't exist
Trace	#0 /var/www/mutillidae/index.php(96): include() #1 {main}
Diagnostic Information	SELECT * FROM accounts WHERE username='admin' AND password='test'

Did you [setup/reset the DB?](#)

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line **148**

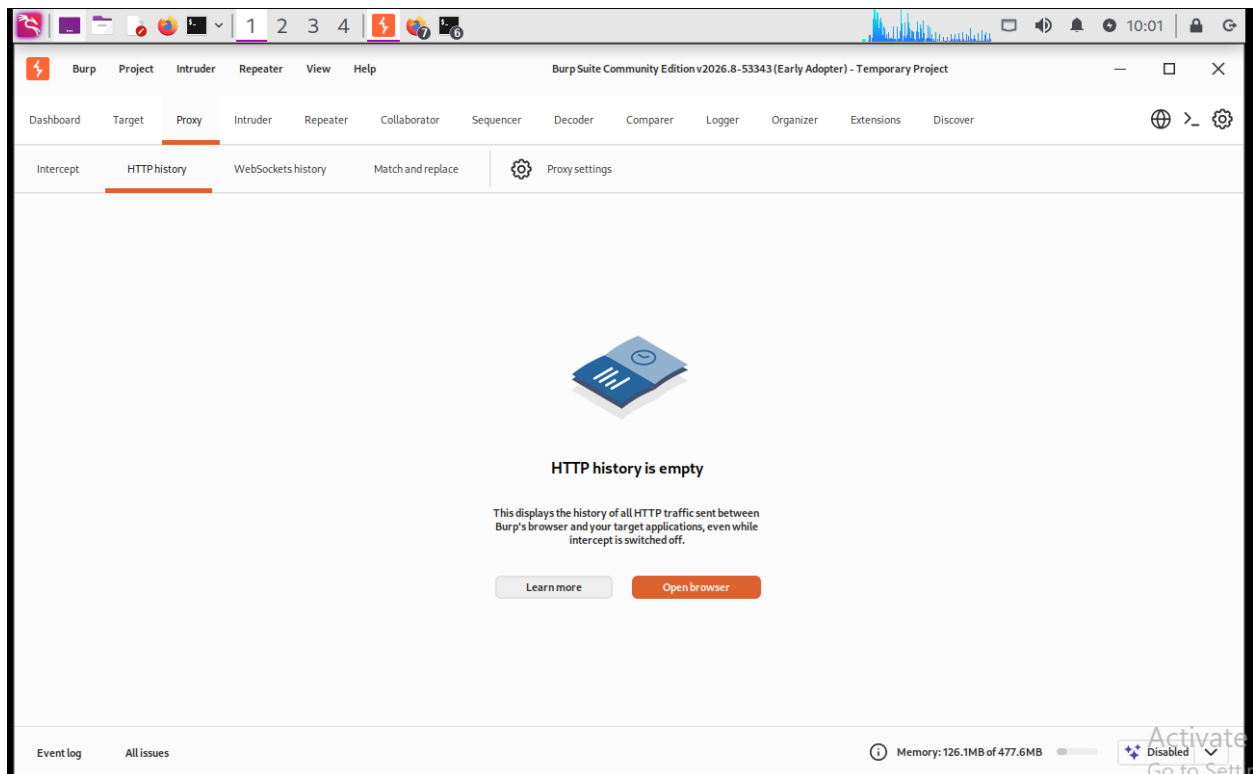
Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line **254**

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line **255**

Warning: Cannot modify header information - headers already sent by (output started at /var/www/mutillidae/process-login-attempt.php:97) in **/var/www/mutillidae/index.php** on line **256**



A banner with a blue background. On the left is a red spider icon. In the center, the text reads "Mutillidae: Born to be Hacked". On the right, the word "Activate" is partially visible.

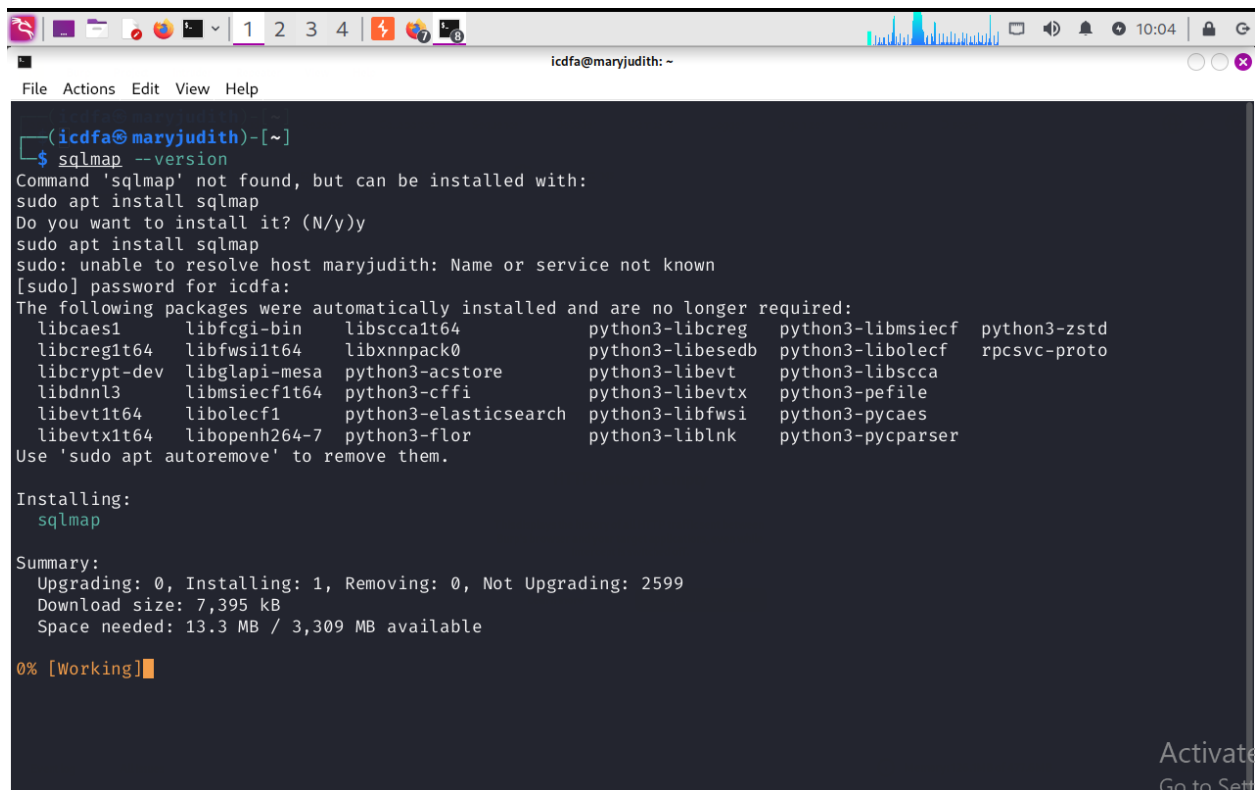


The screenshot shows the Burp Suite interface. The top menu bar includes Burp, Project, Intruder, Repeater, View, and Help. Below the menu is a toolbar with various icons. The main panel is titled "HTTP history is empty" and contains a message: "This displays the history of all HTTP traffic sent between Burp's browser and your target applications, even while intercept is switched off." There are two buttons: "Learn more" and "Open browser". At the bottom, there is a status bar showing "Event log", "All issues", and "Memory: 126.1MB of 477.6MB".

REPORT:

The SQL injection test request was reviewed using available application responses. The login form submitted user-controlled parameters through an HTTP POST request. The parameters included username and password fields supplied by the user. The resulting SQL error demonstrated that the submitted input reached the backend database query. This confirmed that user-controlled input was being processed by the application and provided sufficient evidence for analysis.

Step 26: SQLMap Syntax



```
(icdfa@maryjudith)-[~]
$ sqlmap --version
Command 'sqlmap' not found, but can be installed with:
sudo apt install sqlmap
Do you want to install it? (N/y)y
sudo apt install sqlmap
sudo: unable to resolve host maryjudith: Name or service not known
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
libcaes1 libfcgi-bin libscalt64 python3-libcreg python3-libmsiecf python3-zstd
libcreg1t64 libfws1t64 libxnnpack0 python3-libesedb python3-libolecf rpcsvc-proto
libcrypt-dev libglapi-mesa python3-acstore python3-libevt python3-libscca
libdnnl3 libmsiecf1t64 python3-cffi python3-libvtx python3-pefile
libvt1t64 libolecf1 python3-elasticsearch python3-libfws python3-pycaes
libvtx1t64 libopenh264-7 python3-flor python3-liblnc python3-pycparser
Use 'sudo apt autoremove' to remove them.

Installing:
  sqlmap

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2599
  Download size: 7,395 kB
  Space needed: 13.3 MB / 3,309 MB available

0% [Working]
```

Activate
Go to Set

```
Applications
File Actions Edit View Help

(icdfa@maryjudith)-[~]
$ sqlmap --version
Command 'sqlmap' not found, but can be installed with:
sudo apt install sqlmap
Do you want to install it? (N/y)y
sudo apt install sqlmap
sudo: unable to resolve host maryjudith: Name or service not known
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
libcaes1 libfcgi-bin libscca1t64 python3-libcreg python3-libmsiecf python3-zstd
libcreg1t64 libfws1t64 libxnnpack0 python3-libesdb python3-libolecf rpcsvc-proto
libcrypt-dev libglapi-mesa python3-acstore python3-libevt python3-libscca
libdnnl3 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libevt1t64 libolecf1 python3-elasticsearch python3-libfws1 python3-pycaes
libevtx1t64 libopenh264-7 python3-flor python3-liblnc python3-pycparser
Use 'sudo apt autoremove' to remove them.

Installing:
sqlmap

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2599
Download size: 7,395 kB
Space needed: 13.3 MB / 3,309 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 sqlmap all 1.10.8-1 [7,395 kB]
Fetched 7,395 kB in 39s (188 kB/s)
Selecting previously unselected package sqlmap.
(Reading database... 422199 files and directories currently installed.)
Preparing to unpack ../sqlmap_1.10.8-1_all.deb...
Unpacking sqlmap (1.10.8-1)...
```

```
Applications
File Actions Edit View Help

(icdfa@maryjudith)-[~]
$ sudo apt install sqlmap
sudo: unable to resolve host maryjudith: Name or service not known
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
libcaes1 libfcgi-bin libscca1t64 python3-libcreg python3-libmsiecf python3-zstd
libcreg1t64 libfws1t64 libxnnpack0 python3-libesdb python3-libolecf rpcsvc-proto
libcrypt-dev libglapi-mesa python3-acstore python3-libevt python3-libscca
libdnnl3 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libevt1t64 libolecf1 python3-elasticsearch python3-libfws1 python3-pycaes
libevtx1t64 libopenh264-7 python3-flor python3-liblnc python3-pycparser
Use 'sudo apt autoremove' to remove them.

Installing:
sqlmap

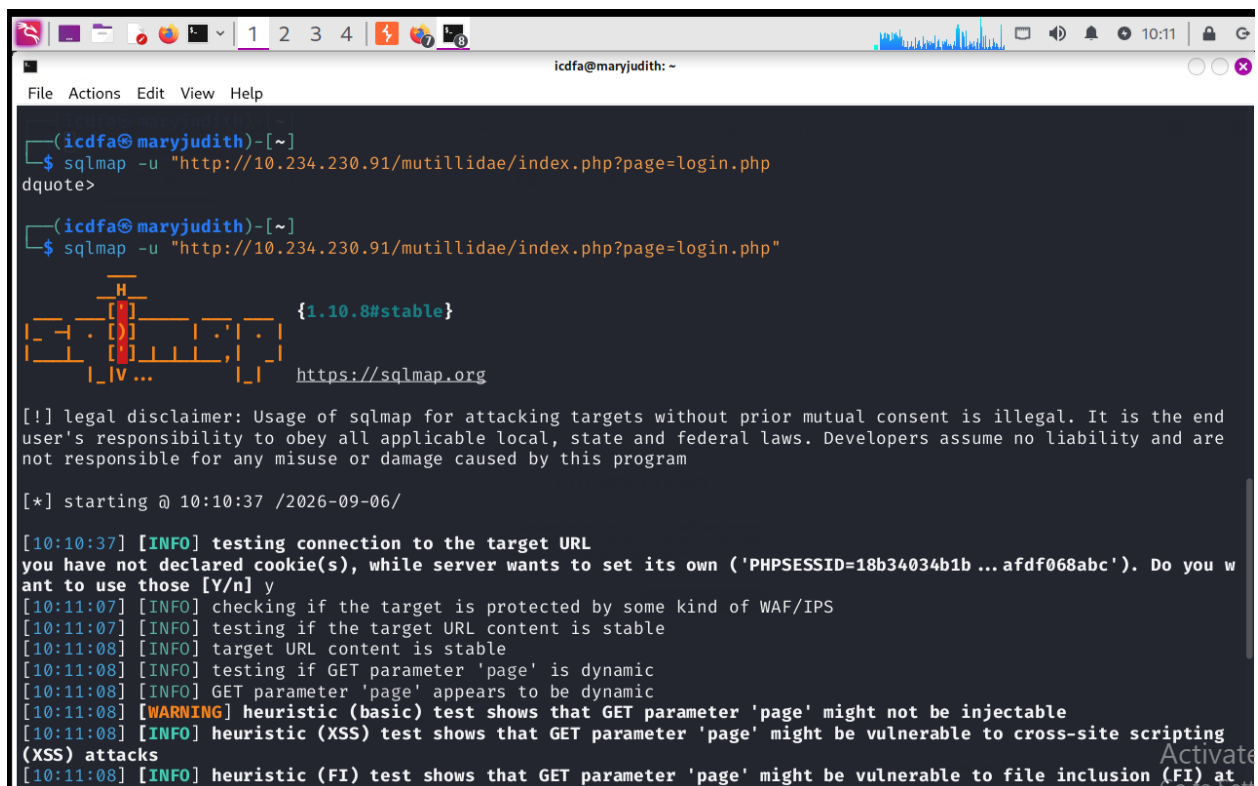
Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2599
Download size: 7,395 kB
Space needed: 13.3 MB / 3,309 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 sqlmap all 1.10.8-1 [7,395 kB]
Fetched 7,395 kB in 39s (188 kB/s)
Selecting previously unselected package sqlmap.
(Reading database... 422199 files and directories currently installed.)
Preparing to unpack ../sqlmap_1.10.8-1_all.deb...
Unpacking sqlmap (1.10.8-1)...
Setting up sqlmap (1.10.8-1)...
Processing triggers for kali-menu (2025.1.1)...
Processing triggers for man-db (2.13.0-1)...
```

REPORT

SQLMap was installed and verified successfully on the Kali Linux system. The tool was prepared for automated SQL injection testing activities. Verifying the installation confirmed that SQLMap was available and ready to assess application parameters. SQLMap provides automated testing and validation of SQL injection vulnerabilities. The successful installation prepared the environment for the remaining database assessment exercises.

Step 27: SQLMap Test

A screenshot of a terminal window on a Kali Linux system. The window title is 'icdfa@maryjudith: ~'. The terminal shows the execution of the 'sqlmap' command with the URL 'http://10.234.230.91/mutillidae/index.php?page=login.php'. The output includes a legal disclaimer, the start time '10:10:37 /2026-09-06/', and a series of status messages. The messages indicate that the connection to the target URL was tested, the target is protected by WAF/IPS, the URL content is stable, and the GET parameter 'page' is dynamic. A warning message states that the heuristic (basic) test shows that the GET parameter 'page' might not be injectable. An information message states that the heuristic (XSS) test shows that the GET parameter 'page' might be vulnerable to cross-site scripting (XSS) attacks. Another information message states that the heuristic (FI) test shows that the GET parameter 'page' might be vulnerable to file inclusion (FI) at 10:11:08. The terminal also shows a progress bar and the URL 'https://sqlmap.org'.

```
(icdfa@maryjudith)-[~]
$ sqlmap -u "http://10.234.230.91/mutillidae/index.php?page=login.php"
dquote>

(icdfa@maryjudith)-[~]
$ sqlmap -u "http://10.234.230.91/mutillidae/index.php?page=login.php"

{1.10.8#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end
user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are
not responsible for any misuse or damage caused by this program

[*] starting @ 10:10:37 /2026-09-06/

[10:10:37] [INFO] testing connection to the target URL
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=18b34034b1b ... afd068abc'). Do you w
ant to use those [Y/n] y
[10:11:07] [INFO] checking if the target is protected by some kind of WAF/IPS
[10:11:07] [INFO] testing if the target URL content is stable
[10:11:08] [INFO] target URL content is stable
[10:11:08] [INFO] testing if GET parameter 'page' is dynamic
[10:11:08] [INFO] GET parameter 'page' appears to be dynamic
[10:11:08] [WARNING] heuristic (basic) test shows that GET parameter 'page' might not be injectable
[10:11:08] [INFO] heuristic (XSS) test shows that GET parameter 'page' might be vulnerable to cross-site scripting
(XSS) attacks
[10:11:08] [INFO] heuristic (FI) test shows that GET parameter 'page' might be vulnerable to file inclusion (FI) at
```



```
Applications
icdfa@maryjudith: ~
[10:11:07] [INFO] checking if the target is protected by some kind of WAF/IPS
[10:11:07] [INFO] testing if the target URL content is stable
[10:11:08] [INFO] target URL content is stable
[10:11:08] [INFO] testing if GET parameter 'page' is dynamic
[10:11:08] [INFO] GET parameter 'page' appears to be dynamic
[10:11:08] [WARNING] heuristic (basic) test shows that GET parameter 'page' might not be injectable
[10:11:08] [INFO] heuristic (XSS) test shows that GET parameter 'page' might be vulnerable to cross-site scripting (XSS) attacks
[10:11:08] [INFO] heuristic (FI) test shows that GET parameter 'page' might be vulnerable to file inclusion (FI) attacks
[10:11:08] [INFO] testing for SQL injection on GET parameter 'page'
[10:11:08] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
[10:11:08] [WARNING] reflective value(s) found and filtering out
[10:11:10] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[10:11:10] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[10:11:11] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[10:11:12] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[10:11:12] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[10:11:13] [INFO] testing 'H2 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (CAST)'
[10:11:13] [INFO] testing 'Generic inline queries'
[10:11:14] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[10:11:14] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[10:11:14] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[10:11:15] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[10:11:15] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[10:11:16] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[10:11:17] [INFO] testing 'Oracle AND time-based blind'
[10:11:18] [INFO] testing 'CUBRID AND time-based blind (SLEEP)'
[10:11:18] [INFO] testing 'CUBRID OR time-based blind (SLEEP)'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found.
Do you want to reduce the number of requests? [Y/n]
```

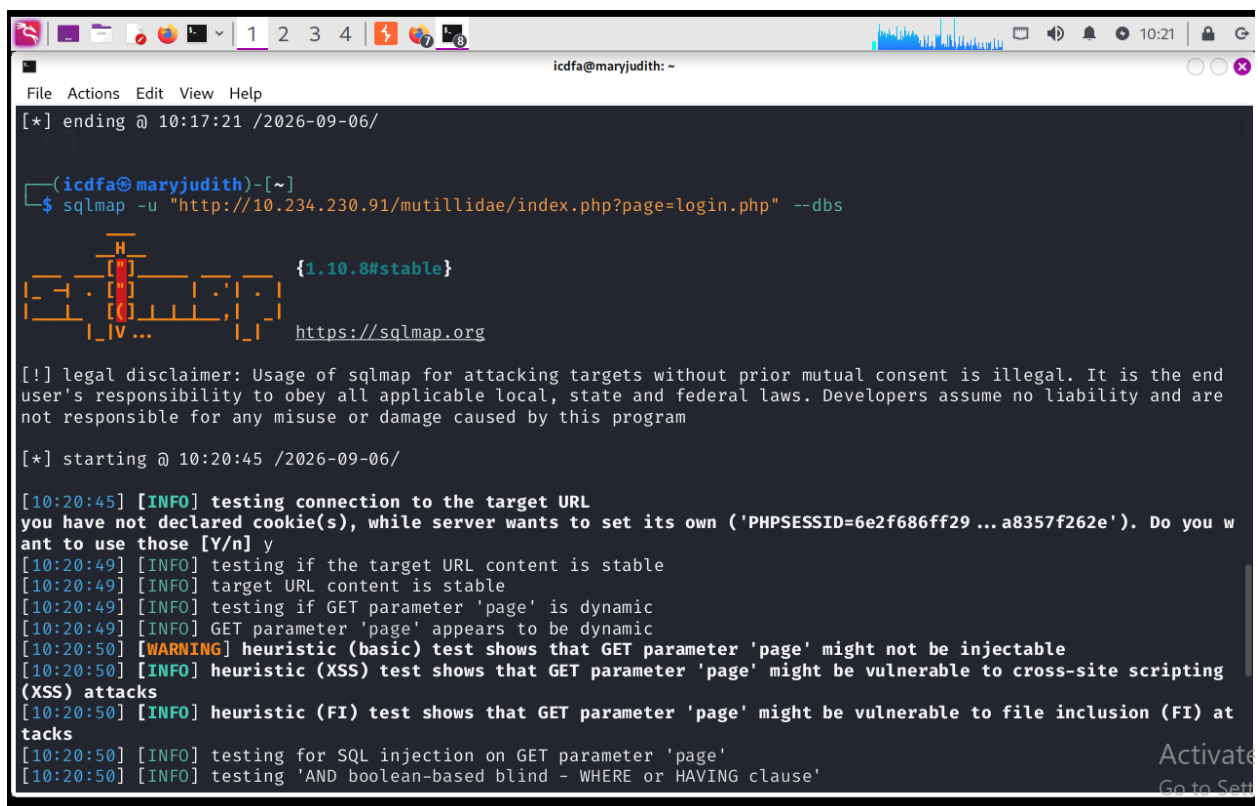
```
icdfa@maryjudith: ~
File Actions Edit View Help
[10:11:08] [WARNING] reflective value(s) found and filtering out
[10:11:10] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'
[10:11:10] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'
[10:11:11] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'
[10:11:12] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'
[10:11:12] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'
[10:11:13] [INFO] testing 'H2 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (CAST)'
[10:11:13] [INFO] testing 'Generic inline queries'
[10:11:14] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'
[10:11:14] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'
[10:11:14] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'
[10:11:15] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[10:11:15] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'
[10:11:16] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'
[10:11:17] [INFO] testing 'Oracle AND time-based blind'
[10:11:18] [INFO] testing 'CUBRID AND time-based blind (SLEEP)'
[10:11:18] [INFO] testing 'CUBRID OR time-based blind (SLEEP)'
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found.
Do you want to reduce the number of requests? [Y/n] y
[10:17:20] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'
[10:17:21] [WARNING] GET parameter 'page' does not seem to be injectable
[10:17:21] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'
[*] ending @ 10:17:21 /2026-09-06/

(icdfa@maryjudith)-[~]
$
```

REPORT

SQLMap was executed against the Mutillidae application to assess the page parameter for SQL injection vulnerabilities. The tool successfully connected to the target application and performed multiple automated tests against the selected parameter. SQLMap determined that the page parameter was dynamic and attempted several injection techniques, including boolean-based, error-based, time-based, and UNION-based tests. After completing the assessment, SQLMap reported that the tested parameter did not appear to be injectable under the current testing conditions. The results demonstrated the use of automated SQL injection testing and highlighted the importance of validating findings through both manual and automated analysis.

Step 28: List Databases

A screenshot of a terminal window titled 'icdfa@maryjudith: ~'. The terminal shows the execution of SQLMap against a target URL. The command entered is 'sqlmap -u "http://10.234.230.91/mutillidae/index.php?page=login.php" --dbs'. The output includes a legal disclaimer, a connection test, and several informational messages about the target URL's content stability and the 'page' parameter's dynamic nature. A warning message states that the 'page' parameter might not be injectable. The terminal also shows the start of a heuristic (XSS) test and a heuristic (FI) test. The window's title bar shows the user 'icdfa' and the host 'maryjudith'. The terminal's status bar at the bottom right shows 'Activate' and 'Go to Setti'.

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
[10:20:50] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[10:20:50] [WARNING] reflective value(s) found and filtering out  
[10:20:51] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[10:20:52] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)'  
[10:20:52] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'  
[10:20:53] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'  
[10:20:54] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'  
[10:20:54] [INFO] testing 'H2 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (CAST)'  
[10:20:55] [INFO] testing 'Generic inline queries'  
[10:20:55] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'  
[10:20:55] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'  
[10:20:56] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'  
[10:20:57] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'  
[10:20:57] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'  
[10:20:58] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'  
[10:20:59] [INFO] testing 'Oracle AND time-based blind'  
[10:20:59] [INFO] testing 'CUBRID AND time-based blind (SLEEP)'  
[10:21:00] [INFO] testing 'CUBRID OR time-based blind (SLEEP)'  
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found.  
Do you want to reduce the number of requests? [Y/n] y  
[10:21:05] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'  
[10:21:06] [WARNING] GET parameter 'page' does not seem to be injectable  
[10:21:06] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'--risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism involved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--random-agent'  
[*] ending @ 10:21:06 /2026-09-06/  
icdfa@maryjudith: ~
```

REPORT

SQLMap was executed with the --dbs option to enumerate databases available on the target application. The tool analyzed the selected page parameter and performed multiple SQL injection tests using different techniques. During testing, SQLMap reported that the parameter appeared dynamic but did not identify a confirmed SQL injection vulnerability. Because no injectable parameter was found, database enumeration could not be performed successfully. The results demonstrated that successful database enumeration depends on the presence of an exploitable SQL injection vulnerability.

tep 29: List Tables

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
[*] ending @ 10:21:06 /2026-09-06/  
  
(icdfa@maryjudith)-[~]  
$ sqlmap -u "http://10.234.230.91/mutillidae/index.php?page=login.php" --tables  
  
{1.10.8#stable}  
  
https://sqlmap.org  
  
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end  
user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are  
not responsible for any misuse or damage caused by this program  
  
[*] starting @ 10:27:07 /2026-09-06/  
  
[10:27:07] [INFO] testing connection to the target URL  
you have not declared cookie(s), while server wants to set its own ('PHPSESSID=27583827453 ... 344d8625f6'). Do you w  
ant to use those [Y/n] y  
[10:27:12] [INFO] testing if the target URL content is stable  
[10:27:12] [INFO] target URL content is stable  
[10:27:12] [INFO] testing if GET parameter 'page' is dynamic  
[10:27:12] [INFO] GET parameter 'page' appears to be dynamic  
[10:27:12] [WARNING] heuristic (basic) test shows that GET parameter 'page' might not be injectable  
[10:27:12] [INFO] heuristic (XSS) test shows that GET parameter 'page' might be vulnerable to cross-site scripting  
(XSS) attacks  
[10:27:12] [INFO] heuristic (FI) test shows that GET parameter 'page' might be vulnerable to file inclusion (FI) at  
tacks  
[10:27:12] [INFO] testing for SQL injection on GET parameter 'page'  
[10:27:12] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'
```

```
icdfa@maryjudith: ~  
File Actions Edit View Help  
[10:27:12] [INFO] heuristic (FI) test shows that GET parameter 'page' might be vulnerable to file inclusion (FI) at  
tacks  
[10:27:12] [INFO] testing for SQL injection on GET parameter 'page'  
[10:27:12] [INFO] testing 'AND boolean-based blind - WHERE or HAVING clause'  
[10:27:13] [WARNING] reflective value(s) found and filtering out  
[10:27:14] [INFO] testing 'Boolean-based blind - Parameter replace (original value)'  
[10:27:14] [INFO] testing 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)  
'  
[10:27:15] [INFO] testing 'PostgreSQL AND error-based - WHERE or HAVING clause'  
[10:27:16] [INFO] testing 'Microsoft SQL Server/Sybase AND error-based - WHERE or HAVING clause (IN)'  
[10:27:16] [INFO] testing 'Oracle AND error-based - WHERE or HAVING clause (XMLType)'  
[10:27:17] [INFO] testing 'H2 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (CAST)'  
[10:27:18] [INFO] testing 'Generic inline queries'  
[10:27:18] [INFO] testing 'PostgreSQL > 8.1 stacked queries (comment)'  
[10:27:18] [INFO] testing 'Microsoft SQL Server/Sybase stacked queries (comment)'  
[10:27:18] [INFO] testing 'Oracle stacked queries (DBMS_PIPE.RECEIVE_MESSAGE - comment)'  
[10:27:19] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'  
[10:27:20] [INFO] testing 'PostgreSQL > 8.1 AND time-based blind'  
[10:27:20] [INFO] testing 'Microsoft SQL Server/Sybase time-based blind (IF)'  
[10:27:21] [INFO] testing 'Oracle AND time-based blind'  
[10:27:21] [INFO] testing 'CUBRID AND time-based blind (SLEEP)'  
[10:27:22] [INFO] testing 'CUBRID OR time-based blind (SLEEP)'  
it is recommended to perform only basic UNION tests if there is not at least one other (potential) technique found.  
Do you want to reduce the number of requests? [Y/n] y  
[10:27:25] [INFO] testing 'Generic UNION query (NULL) - 1 to 10 columns'  
[10:27:26] [WARNING] GET parameter 'page' does not seem to be injectable  
[10:27:26] [CRITICAL] all tested parameters do not appear to be injectable. Try to increase values for '--level'/'-  
-risk' options if you wish to perform more tests. If you suspect that there is some kind of protection mechanism in  
volved (e.g. WAF) maybe you could try to use option '--tamper' (e.g. '--tamper=space2comment') and/or switch '--ran  
dom-agent'  
  
[*] ending @ 10:27:26 /2026-09-06/
```

REPORT

SQLMap was executed using the --tables option to enumerate database tables on the target application. The tool analyzed the selected parameter and applied multiple SQL injection testing techniques to determine whether table enumeration was possible. SQLMap identified the page parameter as dynamic and performed a series of automated tests. However, the assessment did not identify a confirmed injectable parameter and therefore could not retrieve table information. The results showed that table enumeration requires a successfully exploitable SQL injection vulnerability before database schema information can be obtained.

FINAL REPORT

The laboratory successfully demonstrated fundamental web application security testing techniques within a controlled environment. Several tools, including Browser Developer Tools, Burp Suite, Nikto, DIRB, and SQLMap, were used to identify and analyze security-related behaviors and potential weaknesses. Testing showed the risks associated with improper input validation, insecure file uploads, and information disclosure through application errors. The exercises reinforced the importance of secure coding practices, server-side validation, prepared statements, and proper access controls. Overall, the lab provided valuable practical experience in identifying and understanding common web application security issues.

Key Findings

- HTTP requests and cookies can be inspected using browser tools and Burp Suite.
- File upload functionality requires strong validation mechanisms.
- File extensions alone should not be trusted during upload validation.
- Client-supplied MIME types can be manipulated.
- Web-accessible upload directories may introduce security risks.
- Directory discovery tools can reveal hidden application resources.
- Unsanitized user input may result in SQL injection vulnerabilities.
- Detailed database error messages can expose sensitive application information.

Defensive Recommendations

- Validate uploaded files on the server side.
- Use allowlists for approved file types.
- Store uploaded files outside the web root.
- Implement parameterized queries and prepared statements.
- Disable verbose database error messages.
- Apply least-privilege database permissions.
- Validate and sanitize user input.
- Regularly review web server configurations and application security controls.

Part 14 - Student Questions

1. What is the difference between GET and POST?

GET sends data as part of the URL and is commonly used to request information from a web server. POST sends data within the body of the HTTP request and is commonly used when submitting forms or uploading data. GET requests are generally visible in the browser address bar, whereas POST requests are not.

2. What is a parameter?

A parameter is a user-supplied value that is sent to a web application through a URL, form field, cookie, or request body. Parameters allow users to provide information that the application processes and responds to.

3. Why should cookies be hidden in reports?

Cookies often contain session identifiers and authentication information. Exposing these values in a report could allow unauthorized users to hijack a session or gain access to an account. For security reasons, only cookie names should be documented.

4. What is multipart/form-data?

Multipart/form-data is an HTTP content type used when uploading files through web forms. It allows files and form fields to be transmitted together within a single HTTP request.

5. Why are extension and MIME type different?

A file extension is part of the filename, such as .txt or .jpg, while a MIME type describes the format of the file content, such as text/plain or image/jpeg. A file can have one extension while a user changes the MIME type value sent in the request.

6. Why is trusting client Content-Type weak?

The Content-Type header is supplied by the client and can be easily modified before reaching the server. An attacker can change the value to make a file appear harmless, so server-side validation should always be performed.

7. Why should uploads be stored outside an executable web directory?

Storing uploads outside an executable web directory reduces the risk of uploaded files being executed by the web server. This helps prevent attackers from uploading malicious files and running them on the system.

8. What kind of information did Nikto report?

Nikto reported information about web server configuration, HTTP headers, default files, accessible directories, potentially risky settings, and other observations that may require further investigation during a security assessment.

9. What do 200, 301/302, 403 and 404 generally mean in DIRB output?

- 200: The resource exists and was successfully accessed.
- 301/302: The resource redirects to another location.
- 403: Access to the resource is forbidden.
- 404: The resource was not found on the server.

10. Why establish a baseline before SQL tests?

A baseline helps determine how the application behaves under normal conditions. By knowing the expected response, changes caused by testing inputs can be identified more easily and accurately.

11. What happened with a single quote?

A single quote is a special SQL character. In a vulnerable application, entering a single quote may cause an error message or change the application's behavior, indicating that user input is being processed within a database query.

12. How did the true and false conditions differ?

The true condition returned a different result from the false condition because the database evaluated each expression differently. A true statement typically returned matching data, while a false statement returned limited or no results.

13. What did SQLMap automate that you already observed manually?

SQLMap automatically tested parameters, detected SQL injection points, identified the database type, and enumerated database information. These activities confirmed results that were initially observed through manual testing.

14. Why do prepared statements stop input from being interpreted as SQL syntax?

Prepared statements separate SQL commands from user input. The database treats user input as data rather than executable SQL code, preventing attackers from injecting additional SQL commands into queries.

15. Why is authorization mandatory?

Authorization is required to ensure that security testing is conducted legally and ethically. Testing systems without permission may violate laws, policies, and organizational rules, regardless of the testing method used.